

# Burp Suite Kullanımı

## Eğitim Özeti

"Burp Suite Kullanımı" eğitimi, web uygulama güvenliği testi yapmak için en sık kullanılan araçlardan biri olan Burp Suite ile ilgili kapsamlı bir eğitim sunar. Bu eğitim, aracın temelinden ileri düzey kullanımına kadar her yönünü ele alır. Yeni başlayanlar için mükemmel bir giriş noktası sunarken, deneyimli kullanıcılar için de bilgilerini geliştirmelerine olanak sağlar. Kurulum ve konfigürasyon işlemlerinden başlayıp, proxy kullanımı, veri yakalama, güvenlik açıklarını tespit etme ve analiz etme tekniklerine kadar geniş bir yelpazede konuları kapsar.

Eğitim, Burp Suite'in çeşitli modüllerini ve özelliklerini, örneğin Intruder, Repeater, Sequencer, Decoder ve daha fazlasını detaylı bir şekilde inceleyerek, kullanıcıların bu güçlü aracı etkili bir şekilde nasıl kullanacaklarını öğrenmelerini sağlar. Ayrıca, güvenlik testleri sırasında karşılaşılabilecek senaryolara yönelik pratik bilgiler ve ipuçları ile donatılmıştır.



## Burp Suite: Web Güvenliğinin Komuta Merkezi

Web güvenliği denilince akla gelen ilk isim olan **Burp Suite**, PortSwigger tarafından Java tabanlı geliştirilen ve 2003'ten beri sektörün standartlarını belirleyen bir platformdur. Bir web tarayıcısı ile sunucu arasındaki trafiği yöneten, manipüle eden ve analiz eden bir "ara istasyon" (proxy) görevi görür.

### Burp Suite Community

Burp Suite'in ücretsiz versiyonudur ve temel güvenlik test araçlarına erişim sağlar. Otomatik tarama gibi ileri düzey özellikler sunmamasına rağmen, güvenlik testine yeni başlayanlar için önerilir.

Bu versiyon, **Target, Proxy, Intruder, Repeater, Collaborator, Sequencer, Decoder, Comparer, Logger, Organizer, Extensions** gibi çeşitli araçlar içerir.

### **Burp Suite Professional**

Daha deneyimli kullanıcılar için tasarlanmış olan bu ücretli sürüm, Community versiyonunun sunduğu tüm özellikleri kapsar ve ek olarak otomatik güvenlik taraması, gelişmiş tarama motoru, detaylı analiz ve raporlama araçları, Intruder aracının tam erişimli versiyonu gibi ileri düzey özellikler sunar.

### **Burp Suite Enterprise**

Büyük ölçekli kuruluşların ihtiyaçlarına yönelik olarak geliştirilen bu ücretli sürüm, Professional versiyonunun sunduğu tüm özellikleri içerir. Ek olarak, otomatik taramaların planlanması, birden fazla kullanıcı için eş zamanlı tarama yeteneği ve geniş çaplı güvenlik testleri için merkezi bir yönetim arayüzü gibi özellikler sunar. Bu, büyük ekiplerin ve organizasyonların güvenlik testlerini ölçeklendirme ve yönetme ihtiyaçlarına cevap veren gelişmiş özellikler sunar.

## 1. Strateji ve Takip Modülleri

- **Target:** Operasyonun haritasıdır. Hedef sistemin yapısını çıkarır ve kapsamı (scope) yönetir.
- **Logger:** Sahnede ne olup bittiyse kaydeder. Tüm trafik geçmişini buradan izleyebilirsiniz.
- **Organizer:** Karmaşık projelerde notlar almanı ve bulgularını düzenli tutmanı sağlar.

## 2. Trafik Manipülasyonu (En Çok Kullanılanlar)

- **Proxy:** Burp'ün kalbidir. Tarayıcı ile sunucu arasına girip trafiği anlık olarak durdurur ve değiştirmenize izin verir.

- **Repeater:** "Deneme-yanılma" merkezidir. Bir isteęi defalarca, manuel olarak deęiştirip tekrar göndererek sunucunun tepkisini ölçmenizi sağlar.

### 3. Saldırı ve Otomasyon

- **Intruder:** Otomatik saldırı tüfeğidir. Fuzzing ve Brute-force (Kaba kuvvet) saldırıları için özelleştirilmiş senaryolar hazırlar.

*Not: Community versiyonunda hızı kasıtlı olarak düşürülmüştür.*

- **Collaborator:** "Görünmez" açıkların peşindedir (Out-of-band). Dış sistemlerle etkileşime giren karmaşık açıkları yakalamak için **Professional** sürümde yer alır.

### 4. Analiz ve Yardımcı Araçlar

- **Sequencer:** Rastgelelik testi yapar. Özellikle Session (oturum) ID'lerinin tahmin edilebilir olup olmadığını matematiksel olarak analiz eder.
- **Decoder:** Şifre çözücü. URL, Base64 veya Hex gibi kodlanmış verileri saniyeler içinde okunabilir hale getirir.
- **Comparer:** "Görsel fark" dedektifidir. İki farklı yanıt (response) arasındaki en küçük farkları bile vurgulayarak analiz etmenizi sağlar.

## Dashboard: Operasyonun Kontrol Paneli

Burp Suite'i açtığınızda sizi karşılayan **Dashboard**, yürütülen tüm siber güvenlik operasyonunun anlık özetidir. Dağınık verileri bir araya getirerek, taramaların durumunu ve bulunan açıkları tek bir ekranda görmenizi sağlar.

## 1. Otomatik Tarama (Vulnerability Scanning)

Güvenlik açıklarını bulmak için manuel ter dökmek istemediğinizde devreye girer.

- **New Scan:** Tek bir butonla hedef sistemdeki zafiyetleri aramaya başlarsınız.
- **Kontrol Sizde:** Taramaları dilediğiniz an duraklatabilir, önceliklerini değiştirebilir veya devam ettirebilirsiniz.

 *Not: Bu otomatik tarama özelliği **Professional** sürümünün en güçlü silahıdır.*

## 2. Görev Listesi (Issue Activity)

"Arka planda neler dönüyor?" sorusunun cevabı buradadır.

- Aktif devam eden taramalar, tamamlanmış analizler ve sistemin o an meşgul olduğu tüm görevler burada listelenir.
- Hangi görevin ne kadar kaynak tükettiğini ve ne aşamada olduğunu şeffaf bir şekilde görebilirsiniz.

## 3. Güvenlik Uyarıları ve Bulgular (Advisory)

En heyecan verici kısım! Tarama sırasında bir açık bulunduğunda Dashboard sizi uyarır.

- **Detaylı Analiz:** Bulunan her açığın ne olduğu, sunucunun hangi noktasında tetiklendiği ve ne kadar tehlikeli olduğu (Low, Medium, High, Critical) belirtilir.
- **Çözüm Reçetesi:** Sadece "açık var" demez, aynı zamanda bu açığın nasıl kapatılacağına dair teknik öneriler sunar.





## Dashboard: Operasyonun Kontrol Paneli

Burp Suite'i açtığınızda sizi karşılayan **Dashboard**, yürütülen tüm siber güvenlik operasyonunun anlık özetidir. Dağınık verileri bir araya getirerek, taramaların durumunu ve bulunan açıkları tek bir ekranda görmenizi sağlar.



### 1. Otomatik Tarama (Vulnerability Scanning)

Güvenlik açıklarını bulmak için manuel ter dökmek istemediğinizde devreye girer.

- **New Scan:** Tek bir butonla hedef sistemdeki zafiyetleri aramaya başlarsınız.
- **Kontrol Sizde:** Taramaları dilediğiniz an duraklatabilir, önceliklerini değiştirebilir veya devam ettirebilirsiniz.



*Not: Bu otomatik tarama özelliği **Professional** sürümünün en güçlü silahıdır.*



### 2. Görev Listesi (Issue Activity)

"Arka planda neler dönüyor?" sorusunun cevabı buradadır.

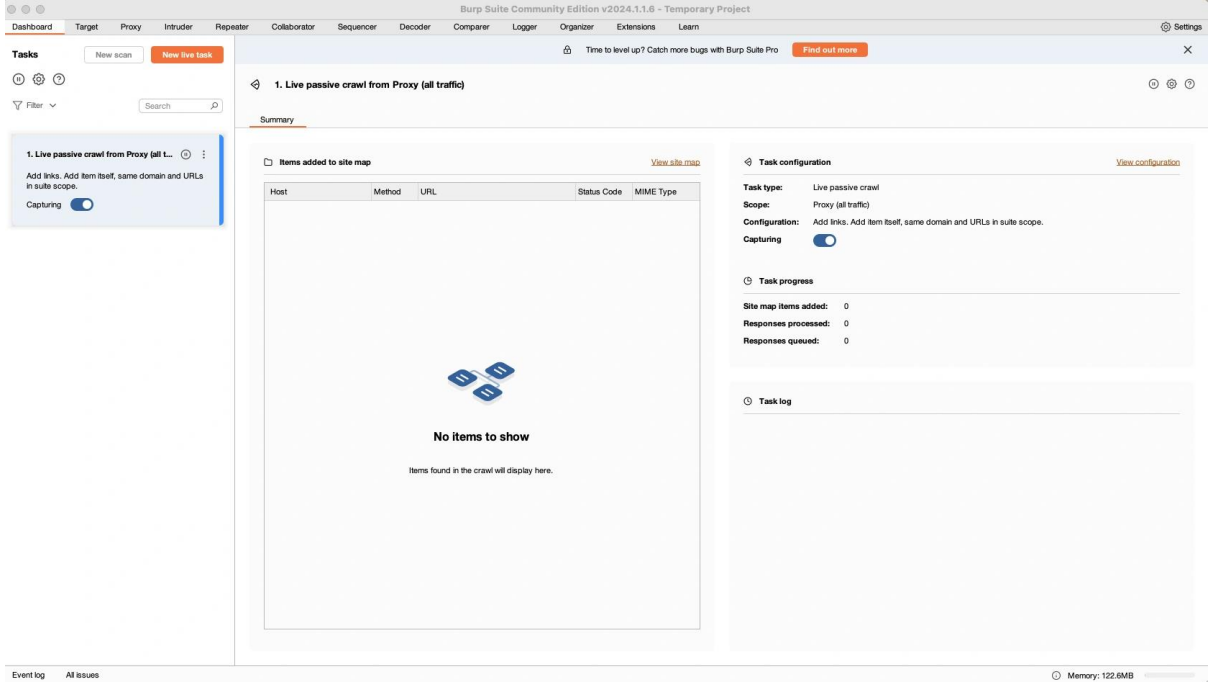
- Aktif devam eden taramalar, tamamlanmış analizler ve sistemin o an meşgul olduğu tüm görevler burada listelenir.
- Hangi görevin ne kadar kaynak tükettiğini ve ne aşamada olduğunu şeffaf bir şekilde görebilirsiniz.



### 3. Güvenlik Uyarıları ve Bulgular (Advisory)

En heyecan verici kısım! Tarama sırasında bir açık bulunduğunda Dashboard sizi uyarır.

- **Detaylı Analiz:** Bulunan her açığın ne olduğu, sunucunun hangi noktasında tetiklendiği ve ne kadar tehlikeli olduğu (Low, Medium, High, Critical) belirtilir.
- **Çözüm Reçetesi:** Sadece "açık var" demez, aynı zamanda bu açığın nasıl kapatılacağına dair teknik öneriler sunar.



## ⚡ Görev Yönetimi: Operasyonun Ritmini Belirleyin

Burp Suite sadece bir araç değil, aynı anda onlarca işi yönetebilen bir **orkestra şefidir**. Dashboard üzerindeki "Tasks" bölümü, arka planda dönen tüm teknik süreci kontrol etmenizi sağlar.

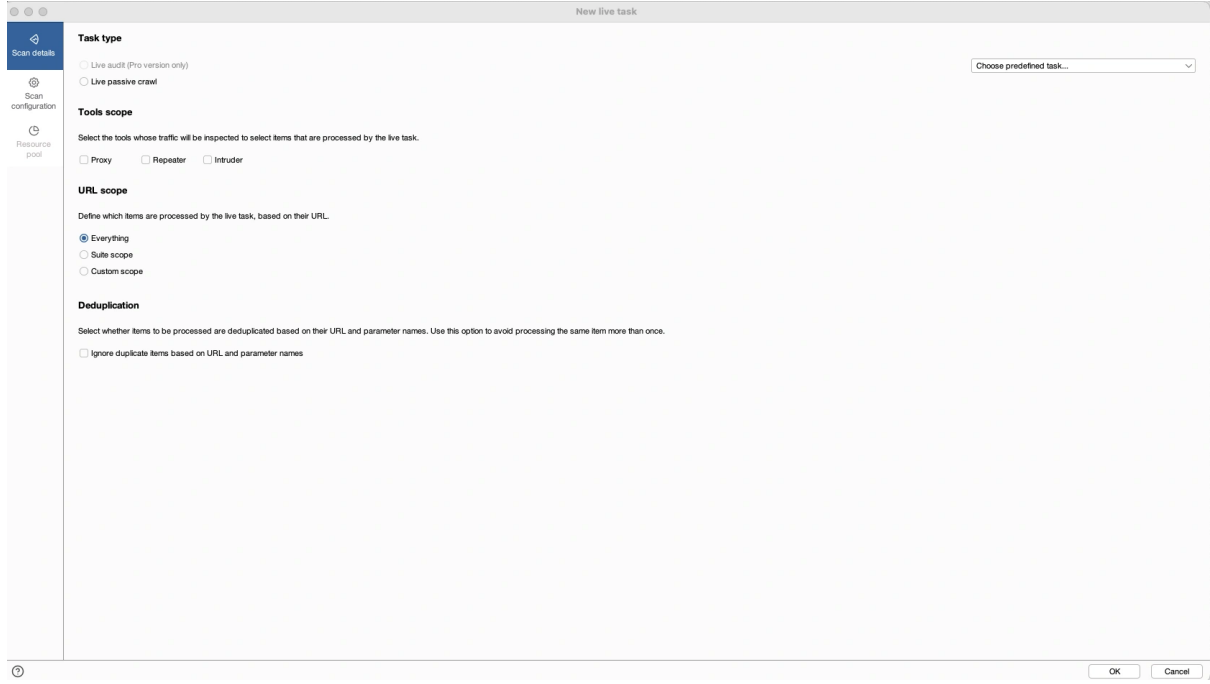
### + Yeni Görev Ekleme (New Live Task)

Sadece statik taramalarla yetinmek istemediğinizde, trafiği anlık olarak analiz eden "Canlı Görevler" oluşturabilirsiniz.

- **Nasıl?** Dashboard'daki New live task butonuna tıklayarak yeni bir analiz başlatabilirsiniz.
- **Ne İşe Yarar?** Siz tarayıcıda gezinirken (Passive Crawl) veya aktif olarak bir yeri kurcalarken Burp'ün arka planda sessizce zafiyet aramasını sağlar.

## Görev Durum Takibi (Status Control)

Hangi operasyonun ne aşamada olduğunu anlamak için karmaşık loglara bakmanıza gerek yok. Görevlerin yanındaki akıllı simgeler size her şeyi anlatır:



Harika, Burp Suite'in en kritik meyvelerini topladığımız "**Güvenlik Uyarıları (Security Advisories)**" kısmına geldik. Burası sadece bir liste değil, bir siber güvenlik uzmanı için **\*\*"Hazine Haritası"\***dır.

GitHub ve Medium serin için bu bölümü "Teşhis ve Tedavi" konseptinde özetleyelim:

## **Güvenlik Uyarıları: Zafiyeti Anlamak ve Reçete Yazmak**

Burp Suite bir açık bulduğunda size sadece "Burada bir sorun var" demez; size o sorunun **kimliğini, yerini ve ilacını** sunar. Dashboard'daki her bir uyarı, profesyonel bir raporun temel taşlarını oluşturur:

## Bir Uyarının Anatomisi

Burp Suite'in sunduğu her zafiyet bildirimi üç altın kurala dayanır:

1.  **Zafiyet Türü (Vulnerability Type):** Düşmanınızın kim olduğunu söyler. Örneğin: *SQL Injection*, *Cross-Site Scripting (XSS)* veya *Insecure Direct Object Reference (IDOR)*. Bu başlık, açığın ciddiyetini (Kritik, Yüksek, Orta, Düşük) belirleyen ilk etikettir.
2.  **Etkilenen Alan (Affected Area):** "Yara tam olarak nerede?" sorusunun cevabıdır. Zafiyetin hangi URL'de, hangi parametrede (örneğin: `id=123`) veya hangi HTTP başlığında (Header) tetiklendiğini net bir şekilde gösterir.
3.  **Açıklama ve Öneriler (Description & Remediation):** Burası işin eğitim kısmıdır.
  - a. **Açıklama:** Bu açığın teknik olarak nasıl çalıştığını ve bir saldırganın bu yolu kullanarak neler yapabileceğini anlatır.
  - b. **Öneriler:** Yazılımcılara bu açığı nasıl yamayacaklarına (patch) dair teknik tavsiyeler sunar.

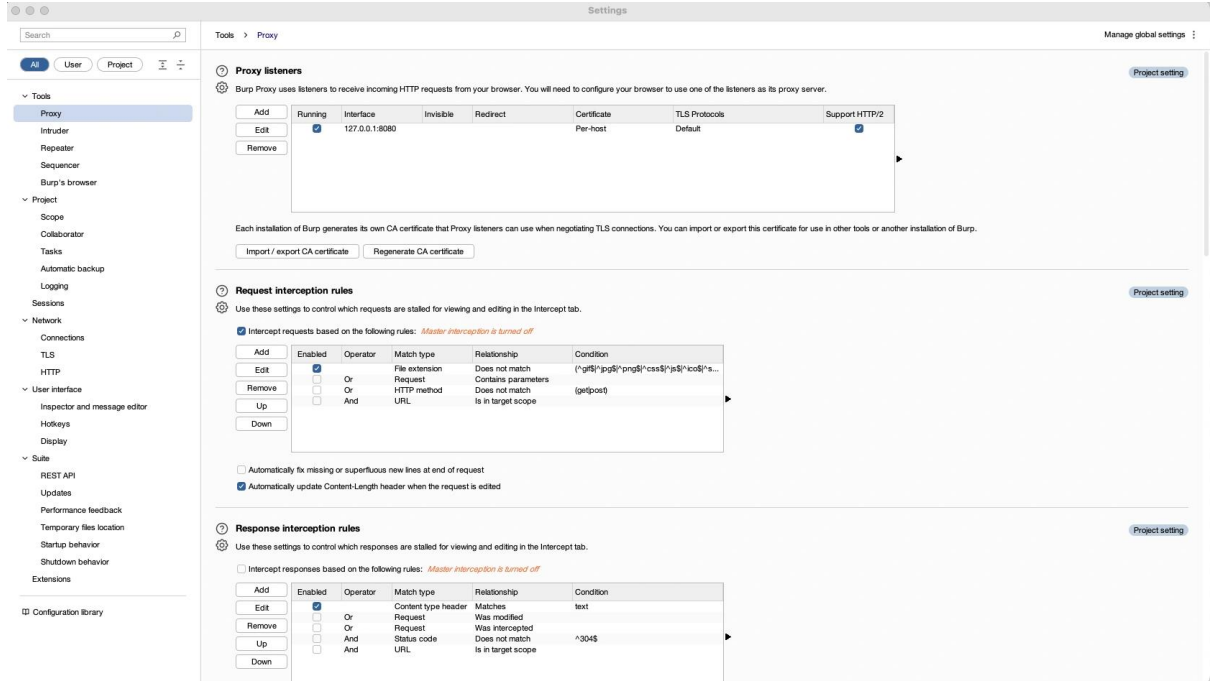
## Neden Bu Kadar Önemli?

Bu uyarılar sayesinde sadece bir "araç kullanıcısı" değil, aynı zamanda bir "**danışman**" olursunuz. Müşterinize veya şirketinize sunacağınız raporda yer alacak teknik detaylar tam olarak buradan beslenir.

**Hızlı İpucu:** Burp Suite Professional kullanıyorsanız, bu uyarıları doğrudan HTML veya XML formatında dışa aktararak profesyonel sızma testi raporlarınızın temelini saniyeler içinde oluşturabilirsiniz.

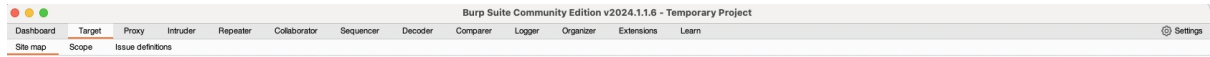
## Ayarlar ve Kişiselleştirme: Kontrol Tamamen Sizde

Burp Suite'in sağ üst köşesindeki o küçük **dişli çark (Settings)** simgesi, aslında devasa bir kontrol panelinin kapısıdır. Burayı doğru yapılandırmak, hem tarama hızınızı artırır hem de hedefe göre esneklik sağlar.



## Target Modülü: Hedefin Dijital Röntgeni

Burp Suite'in üst menüsünde yer alan **Target**, test ettiğiniz web uygulamasının tüm yapısını bir klasör düzeninde görmenizi ve odak noktanızı (Scope) belirlemenizi sağlar. İki ana silahtan oluşur:



## Site Map: Veriyi Bilgiye Dönüştürmek

Site Map sekmesi, sadece bir liste değil; web uygulamasının tüm davranışlarını, giriş-çıkış kapılarını ve zayıf noktalarını gösteren dinamik bir veri merkezidir.

### 1. Akıllı Filtreleme (Noise Reduction)

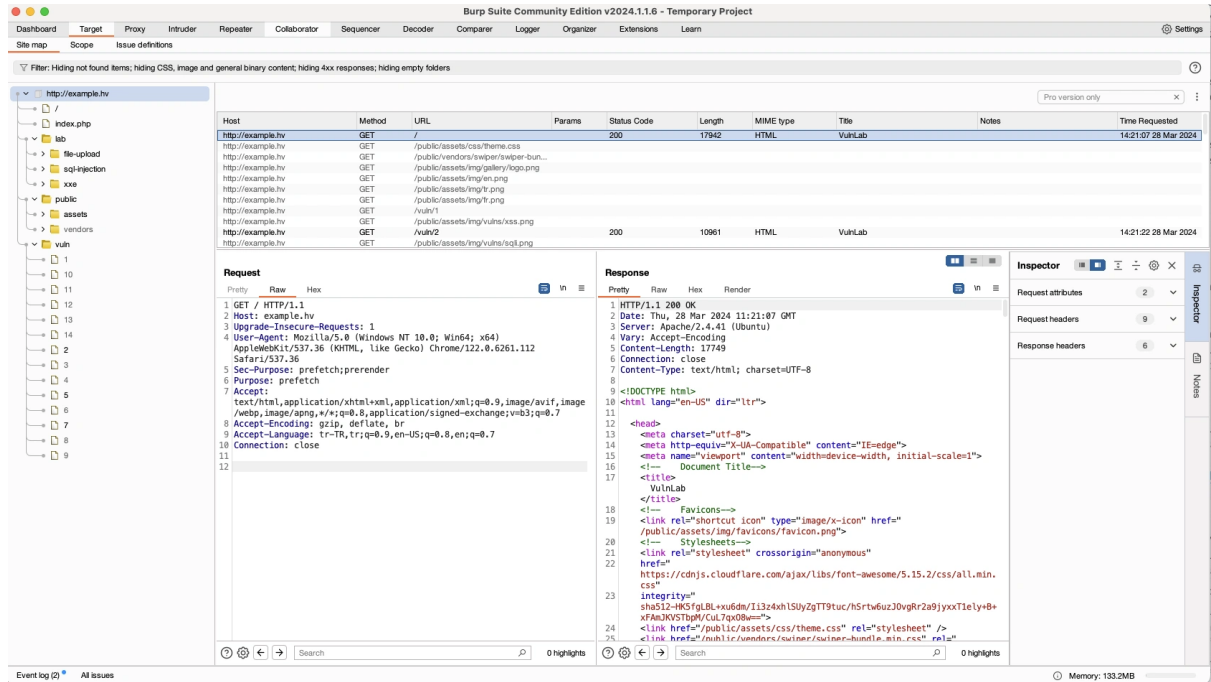
Gerçek bir sızma testinde karşınıza binlerce görsel (.jpg, .png) ve stil dosyası (.css) çıkar. Bunlar genellikle zafiyet barındırmaz ve kalabalık yapar.

- **Gereksizleri Gizle:** Resim, script veya CSS dosyalarını filtreleyerek sadece PHP, ASP, JSON gibi kritik dosyalara odaklanabilirsiniz.
- **Metod Odaklı Çalış:** Sadece veri gönderen POST isteklerini veya sadece veri çeken GET isteklerini listeleterek saldırı yüzeyinizi daraltın.

## 2. İstek ve Yanıtın Anatomisi (Request & Response)

Site haritasında bir URL'ye tıkladığınızda, ekranın alt panelinde o işlemin tüm "arka plan konuşmaları" belirir. Bu, bir dedektifin parmak izi incelemesine benzer:

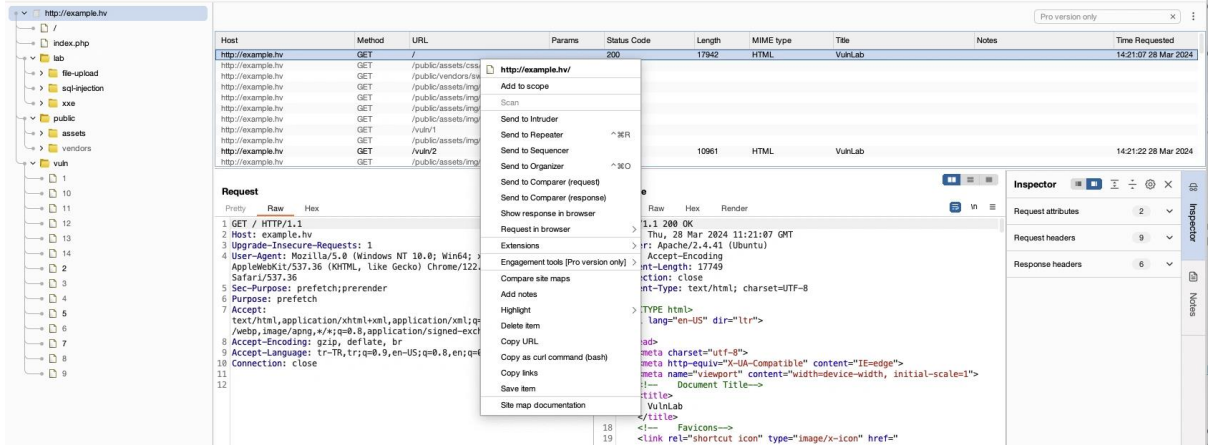
-  **Request (İstek):** Sizin (istemcinin) sunucuya gönderdiğiniz mektuptur. Hangi tarayıcıyı kullandığınız, hangi çerezlere (cookie) sahip olduğunuz ve hangi veriyi gönderdiğiniz burada yazar.
-  **Response (Yanıt):** Sunucunun size verdiği cevaptır. "Giriş başarılı" mı dedi, yoksa "Seni tanımıyorum (401 Unauthorized)" mu? Sunucunun versiyonu, kullanılan programlama dili ve dönen verinin boyutu burada gizlidir.



The screenshot displays the Burp Suite Community Edition v2024.1.1.6 interface. The top menu bar includes options like Dashboard, Target, Proxy, Intruder, Repeater, Collaborator, Sequencer, Decoder, Comparer, Logger, Organizer, Extensions, and Learn. The main workspace is divided into three panels: a Site map on the left, a list of requests in the center, and a detailed view of a selected request and response on the right.

The Site map on the left shows a directory structure for 'http://example.hv' with folders like 'index.php', 'lab', 'file-upload', 'sql-injection', 'xss', 'public', 'assets', 'vendors', and 'vuln'. The central panel lists several requests, including GET requests to various assets and a POST request to '/vuln/2'. The right panel shows the details of a selected request (HTTP/1.1 200 OK) and its response (HTML document titled 'VulnLab'). The response details include headers like 'Date: Thu, 28 Mar 2024 11:21:07 GMT', 'Server: Apache/2.4.41 (Ubuntu)', and 'Content-Type: text/html; charset=UTF-8'. The response body shows the HTML structure of the page, including a title 'VulnLab' and various links and scripts.

Listede bulunan istek kayıtlarının üzerinde farenin sağ tık tuşuna basıldığında isteğin üzerinde yapılabilecek işlemlerin bulunduğu bir menü görüntülenmektedir. Bu isteğin diğer Burp Suite araçlarına gönderilmesi, adresin kopyalanması ya da adresin tarayıcıda görüntülenmesi gibi birçok özellik bu menü içerisinde sunulmaktadır.



## 🎯 Scope: Operasyonun Sınırlarını Çizmek

Bir web uygulamasını test ederken binlerce gereksiz trafik (reklamlar, sosyal medya butonları, analiz servisleri) araya karışır. **Scope**, bu gürültüyü susturup sadece hedefimize odaklanmamızı sağlayan bir "odak merceğidir".

### + 1. Ekleme ve Çıkarma (Include/Exclude)

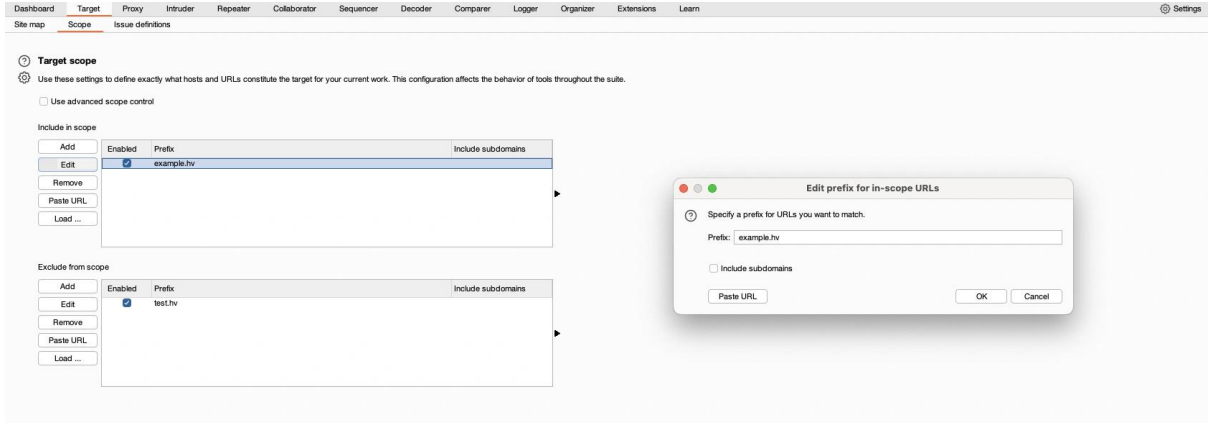
Scope panelinin en temel görevi, hangi adreslerin "dost" hangilerinin "konu dışı" olduğunu belirlemektir.

- **Include:** Sadece izin aldığınız ve test etmek istediğiniz ana alan adını (Örn: \*.hedefsite.com) buraya eklersiniz.
- **Exclude:** Hedef sitenin içinde yer alan ancak dokunmamanız gereken hassas alanları (Örn: admin.hedefsite.com/odeme-kanalı) kapsam dışı bırakabilirsiniz.

### 🔍 2. Gelişmiş Filtreler (Regex Gücü)

Basit bir URL eklemenin ötesinde, **URL Pattern** (düzenli ifadeler) kullanarak çok daha akıllı seçimler yapabilirsiniz:

- Sadece belirli portları (Örn: 8443) kapsama alabilirsiniz.
- Belirli dosya uzantılarını veya dizin desenlerini otomatik olarak filtreleyebilirsiniz.

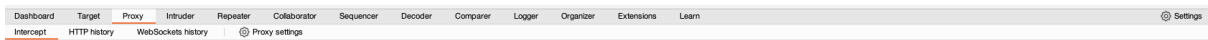


## Proxy: Web Trafiğinin Dijital Gümrüğü

Burp Suite Proxy, tarayıcın ile hedef sunucu arasına yerleşen bir "ara istasyon"dur. Bu modül sayesinde, giden her isteği (Request) ve gelen her yanıtı (Response) durdurup inceleyebilir, hatta üzerinde değişiklik yapabilirsin.

### Proxy Nedir? (Kısaca)

Proxy, ağdaki iki bilgisayar arasındaki iletişime aracılık eden bir sistemdir. Bir web sitesine gitmek istediğinde, tarayıcın doğrudan siteye gitmek yerine önce Burp Suite'e uğrar. Burp bu trafiği yakalar, sana gösterir ve sen onay verene kadar bekletir.



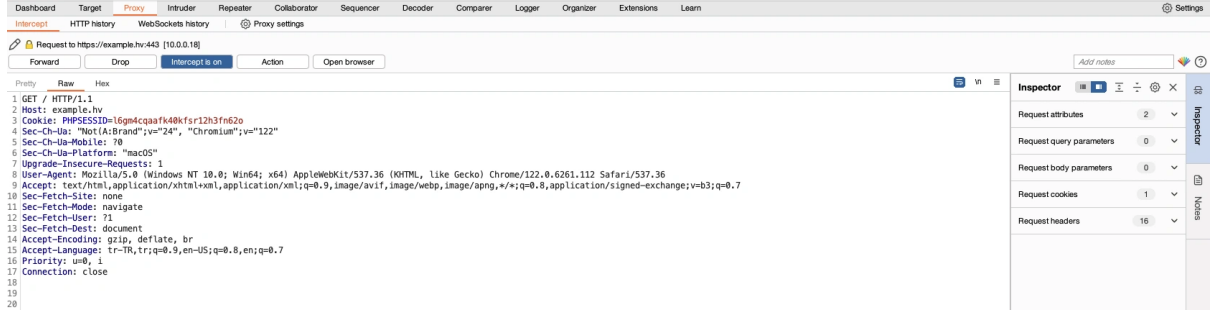
## Intercept: Zamanı Durdurma Sanatı

Proxy modülünün altındaki **Intercept** sekmesi, web trafiği üzerinde mutlak hakimiyet kurmanızı sağlar. Bu özellik, tarayıcınızdan çıkan bir isteğin "yola çıkmasını" engeller ve onu Burp ekranında bir kağıt gibi önünüze serer.

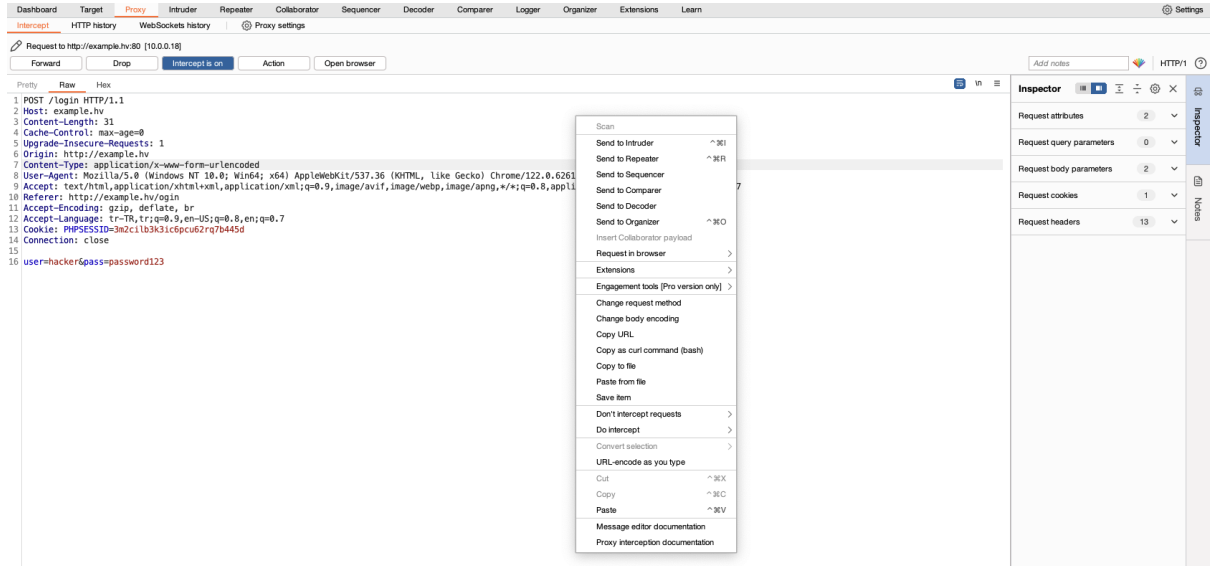


## İki Temel Mod: On vs. Off

- **Intercept is ON (Aktif):** Trafiği durduran baraj kapağıdır. Tarayıcıdan bir butona bastığınızda sayfa yüklenmez, bekler. İstek Burp'e düşer. Siz "Forward" (Gönder) demeden veri sunucuya ulaşmaz.
- **Intercept is OFF (Pasif):** Trafik bir nehir gibi akar. Burp sadece izler ve kayıt (HTTP History) tutar, ancak müdahale etmez.



Ayrıca boş bir noktada farenin sağ tık tuşuna basıldığında isteğin üzerinde yapılabilecek işlemlerin bulunduğu bir menü görüntülenmektedir. Bu isteğin diğer Burp Suite araçlarına gönderilmesi, adresin kopyalanması ya da adresin tarayıcıda görüntülenmesi gibi birçok özellik bu menü içerisinde sunulmaktadır.



Burp Suite'in "trafik polisliğini" yaptığın **Intercept** sekmesinde, sadece durdurmak yetmez; o trafiğe ne yapacağını bilmek gerekir. GitHub ve Medium içeriklerin için bu aksiyon butonlarını bir "**Karar Mekanizması**" olarak özetleyelim:



## Intercept Aksiyonları: Trafiği Yöneten Düğmeler

Intercept ekranında bir isteği yakaladığında, o veri paketi havada asılı kalır. Süreci ilerletmek için şu üç temel fonksiyonu kullanırsın:



### 1. Forward (İleri)

Bu buton, "İncelemem bitti, devam edebilirsin" demektir.

- **İşlevi:** Yakaladığın isteği veya üzerinde değişiklik yaptığın (manipüle edilmiş) veriyi sunucuya gönderir.
- **Ne Zaman Kullanılır?** Parametreyi değiştirdikten sonra sonucu görmek için veya isteğin temiz olduğuna karar verdiğinde kullanılır.



### 2. Drop (Bırak / Yok Et)

Bu buton, trafiği sunucuya ulaşmadan "öldürür".

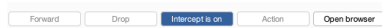
- **İşlevi:** Seçilen isteği çöpe atar. Sunucu bu isteği hiç almaz, tarayıcı ise isteğin başarısız olduğunu bildiren bir hata alır.
- **Ne Zaman Kullanılır?** Yanlışlıkla tetiklenen veya sunucuya gitmesini istemediğin (örneğin sürekli arka planda çalışan gereksiz bir takip kodu) istekleri engellemek için kullanılır.



### 3. Action (İşlem Menüsü)

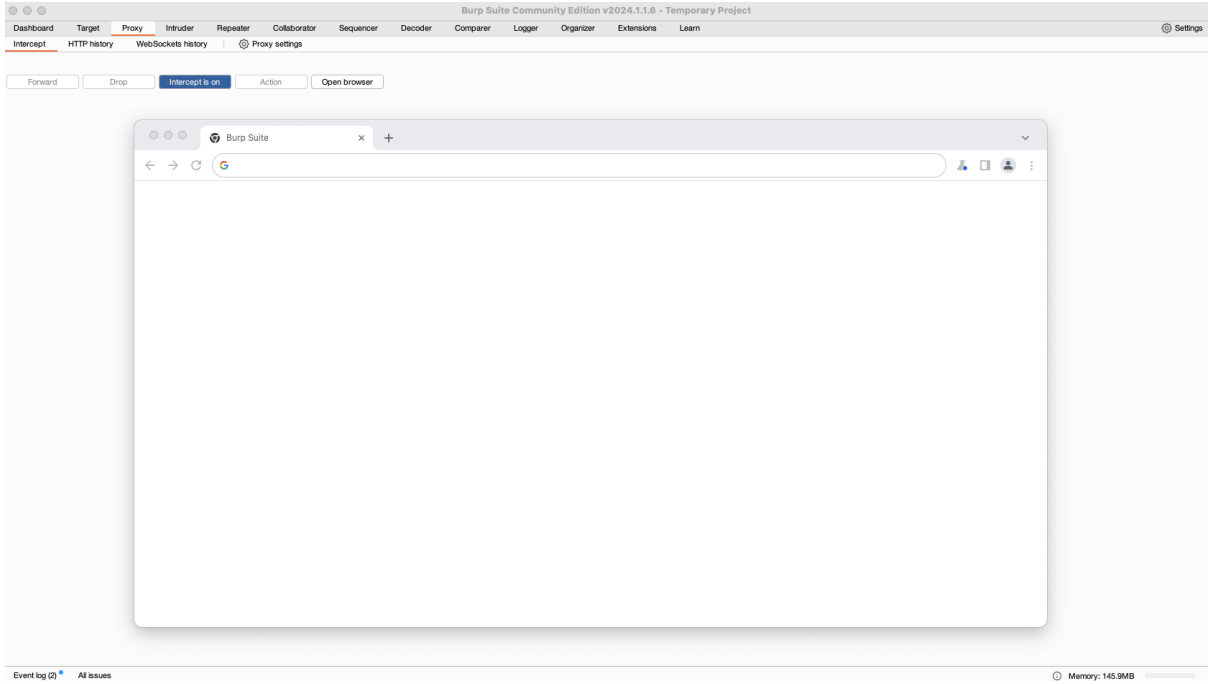
Burası "İsviçre Çakısı" içindeki en hızlı kısayoldur.

- **İşlevi:** Yakaladığın o anki isteği sağ tıklamaya gerek kalmadan diğer Burp modüllerine paslar.
- **Gücü:** Tek tıkla isteği **Repeater**'a kopyalayabilir, **Intruder**'a gönderebilir veya bu isteğin kapsamını (Scope) anlık olarak değiştirebilirsin.



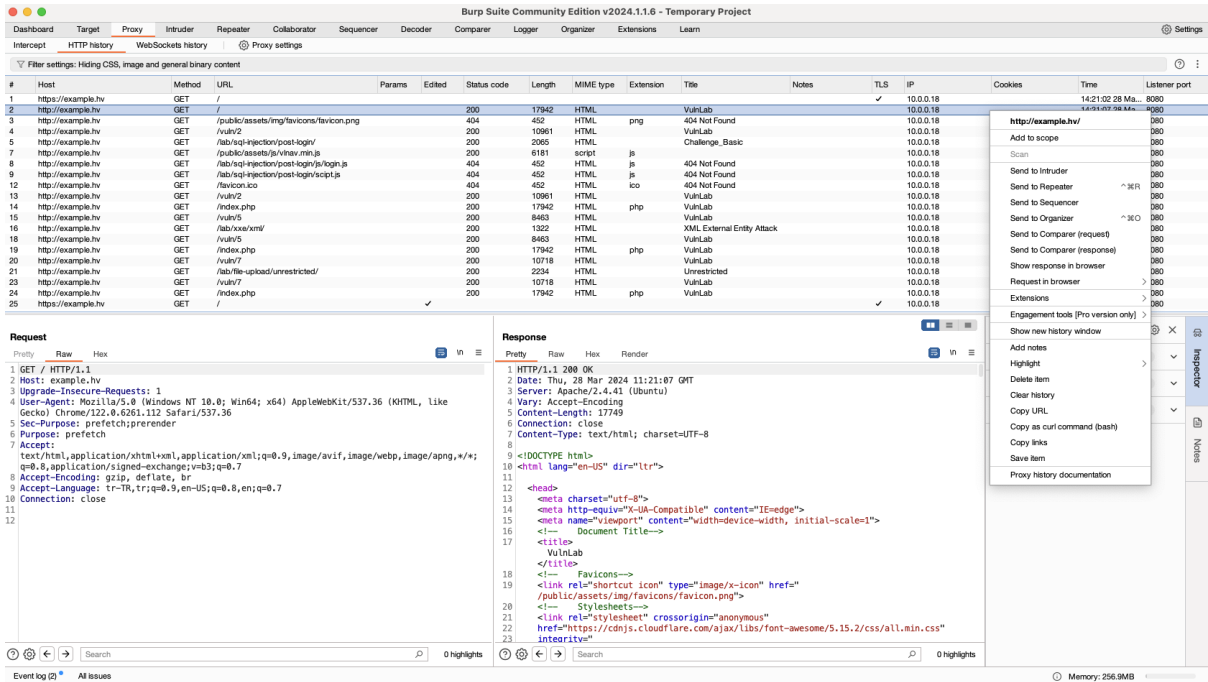
### 4. Open Browser

- **Open Browser:** Harici bir tarayıcı kullanılmasına, sertifika ve proxy ayarı yapılmasına gerek duyulmadan Burp Suite için özel olarak hazırlanmış Chromium alt yapısına sahip tarayıcıyı açar.



## HTTP History: Operasyonun Dijital Arşivi

**HTTP History**, Proxy üzerinden geçen tüm trafiğin saniye saniye kaydedildiği yerdir. Intercept modunda trafiği durdurmasanız bile, Burp arka planda her şeyi buraya not eder.





## WebSockets History: Canlı Veri Akışının Takibi

Geleneksel HTTP trafiği bir mektuplaşma gibidir; sen istersin, sunucu cevap verir ve bağlantı kapanır. Ancak **WebSocket**, istemci ile sunucu arasında kurulan "açık bir telefon hattı" gibidir. **WebSockets History** sekmesi, bu hattan geçen tüm canlı mesajları yakalar.



### WebSocket Nedir?

WebSocket, tarayıcı ve sunucu arasında **çift yönlü (full-duplex)** ve gerçek zamanlı iletişim kuran bir protokoldür.

- **Bağlantı Hiç Kesilmez:** Bir kez el sıkışma (handshake) yapıldıktan sonra veri her iki yöne de anlık akar.
- **Kullanım Alanları:** Canlı borsa grafikleri, chat uygulamaları, online oyunlar ve anlık bildirimler.

Dashboard

Target

Proxy

Intruder

Repeater

Collaborator

Sequencer

Decoder

Comparer

Logger

Organizer

Extensions

Learn

Intercept

HTTP history

WebSockets history

Proxy settings

Filter settings: Showing all items

| #  | URL                    | Direction   | Edited | Length | Notes | TLS | Time                 | Listener port | WebSocket ID |
|----|------------------------|-------------|--------|--------|-------|-----|----------------------|---------------|--------------|
| 26 | http://10.0.0.14:1337/ | ← To client |        | 5      |       |     | 16:35:36 28 Mar 2024 | 8080          | 5            |
| 27 | http://10.0.0.14:1337/ | ← To client |        | 5      |       |     | 16:35:54 28 Mar 2024 | 8080          | 6            |
| 28 | http://10.0.0.14:1337/ | ← To client |        | 5      |       |     | 16:35:55 28 Mar 2024 | 8080          | 7            |
| 29 | http://10.0.0.14:1337/ | ← To client |        | 5      |       |     | 16:35:55 28 Mar 2024 | 8080          | 8            |
| 30 | http://10.0.0.14:1337/ | ← To client |        | 5      |       |     | 16:35:55 28 Mar 2024 | 8080          | 9            |
| 31 | http://10.0.0.14:1337/ | ← To client |        | 5      |       |     | 16:35:55 28 Mar 2024 | 8080          | 10           |

Message

Pretty

Raw

Hex

1

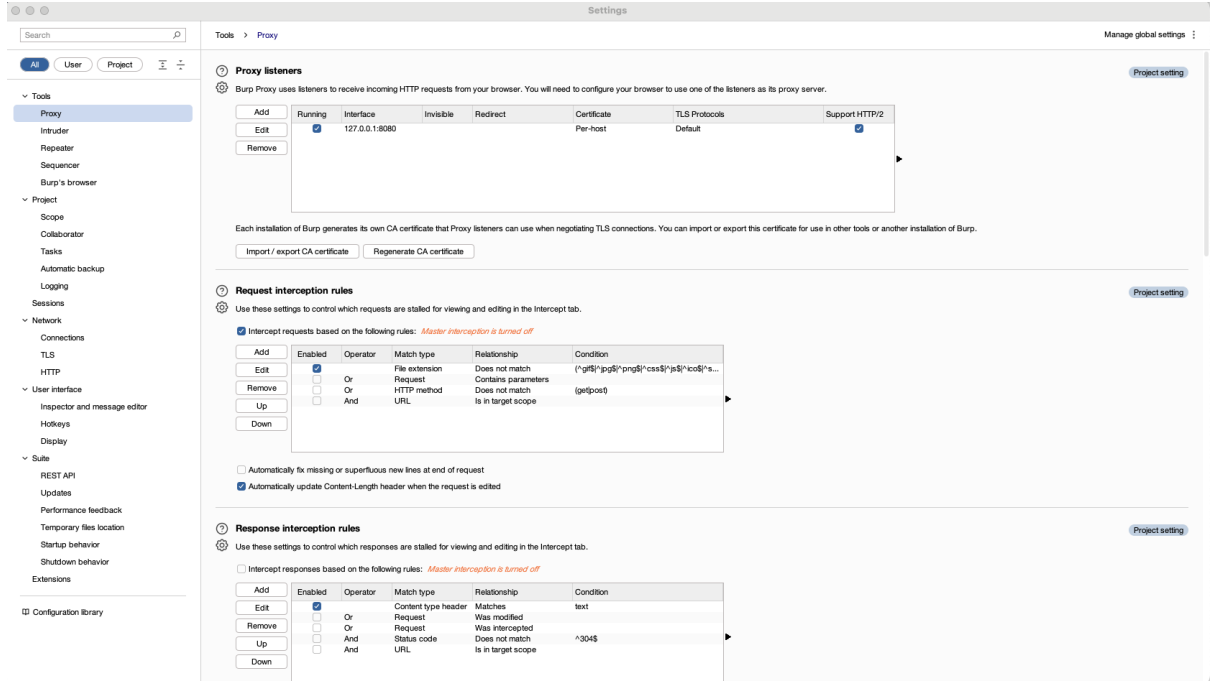
hello

Inspector

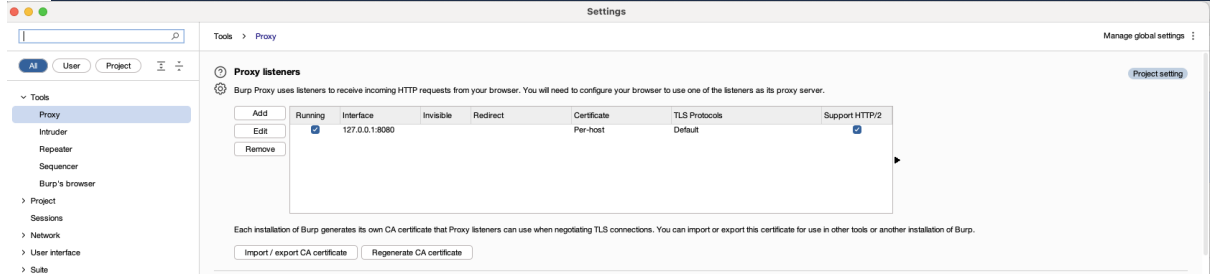


## Proxy Settings: Bağlantı ve Güvenlik Yönetimi

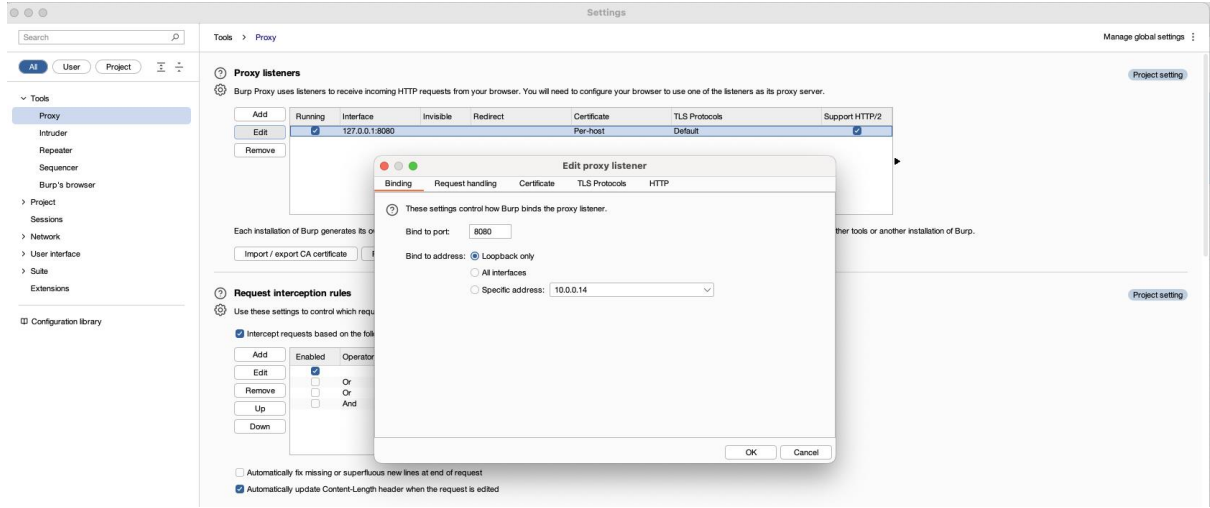
Proxy ayarları, Burp Suite'in dış dünya ile (tarayıcılar ve sunucular) nasıl iletişim kuracağını belirleyen teknik komuta merkezidir. Sadece bir "port" belirlemekten çok daha fazlasını sunar.



- **Proxy Listeners:** Proxy dinleyicileri, Burp Suite'in hangi IP adresleri ve portlar üzerinden ağ trafiğini dinleyeceğini belirler. Birden fazla dinleyici ekleyebilir ve her birinin özelliklerini ayrı ayrı yapılandırabilirler.



Burp Suite Proxy port numarası ya da adresi 'Edit' butonu ile düzenlenebilir ya da 'Add' butonu ile yeni bir dinleme noktası oluşturulabilir.



Bu özellik, Burp Suite'in "akıllı filtreleme" sistemidir. Binlerce istek arasından sadece işimize yarayanları cımbızla çekmemizi sağlar. GitHub ve Medium içeriklerin için bu bölümü "**Gürültü Engelleme**" temasıyla özetleyelim:

## Request Interception Rules: Trafiği Filtreleme Sanatı

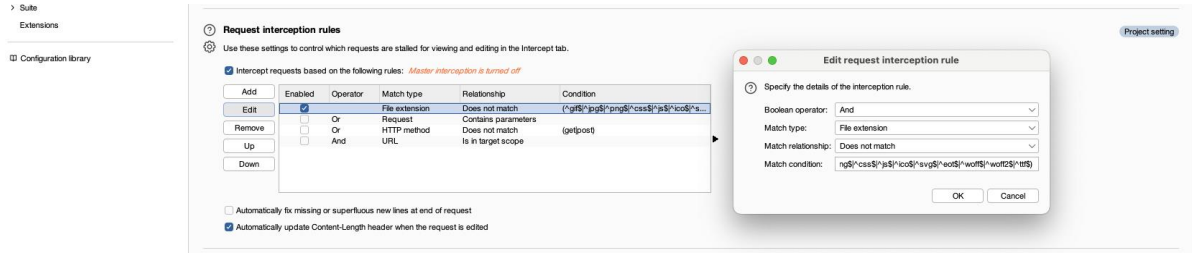
Her web sayfası açıldığında arka planda onlarca resim, stil dosyası (CSS) ve analiz kodu yüklenir. Eğer her şeyi durdurmaya kalkarsanız, testi bitirmeniz günler sürer. **Request Interception Rules**, Burp Suite'e "Bana sadece önemli olanları göster" deme yolunuzdur.

### Kuralların Çalışma Mantığı

Bu bölüm, belirli kriterlere (koşullara) dayalı bir "bekçi" gibi çalışır. Bir isteğin durdurulması için belirlediğiniz kurallara uyması gerekir.

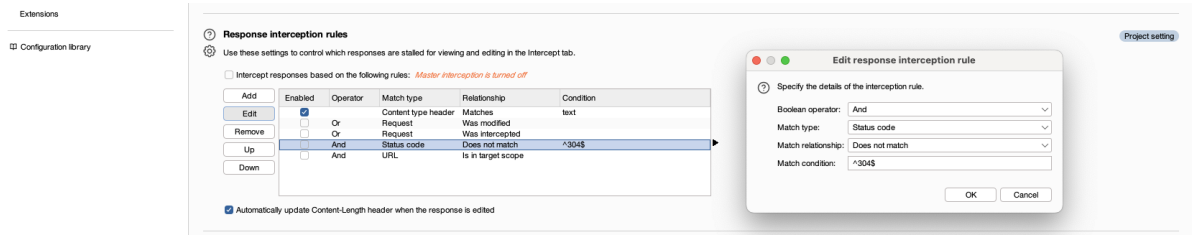
- **Dosya Uzantısı Filtreleme:** En yaygın kullanım budur. Örneğin; .jpg, .png, .css, .js veya .gif gibi dosyaların durdurulmasını engelleyerek, sadece dinamik sayfaları (.php, .asp, .json) inceleyebilirsiniz.
- **Koşullu Yakalama:** "Sadece POST metoduna sahip istekleri durdur" veya "Sadece admin kelimesi içeren URL'leri yakala" gibi spesifik emirler verebilirsiniz.

- **Eşleşmeme (Does Not Match):** Görseldeki örnekte olduğu gibi; "Eğer dosya uzantısı şu listedekilerden biriye, bunu durdurma ve geçmesine izin ver" diyerek trafiği sadeleştirebilirsiniz.



- **Response Interception Rules:** Sunucudan gelen yanıtların nasıl ele alınacağını belirleyen kuralların oluşturulmasını sağlar. İsteklere benzer şekilde, belirli yanıtların kesilmesi için koşullar tanımlanabilir.

Görselde verilen örnek kuralda yakalanacak olan yanıtların HTTP durum kodunun eşleşmemesi gereken değeri belirtilmiştir.



## Harici Tarayıcı Kullanımı ve Sertifika Yönetimi

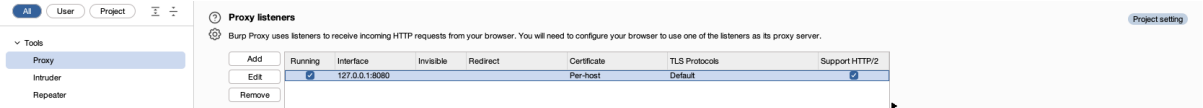
Burp Suite'in kendi içerisinde sunduğu sertifika ve proxy ayarları yapılmış tarayıcının kullanılmak istenilmediği durumlarda harici tarayıcı tercih edilebilmektedir.

**Not:** Burp Suite içerisindeki tarayıcı kullanılmak isteniyorsa bu başlık altında anlatılan adımların gerçekleştirilmesine gerek yoktur.

Burp Suite, harici bir tarayıcıya sertifika yüklemeyi ve Burp Suite'e bağlamayı destekler. Bu, tarayıcıların Burp Suite tarafından yakalanan SSL trafiğini güvenli şekilde incelemesine olanak tanır. Ayrıca, Burp Tarayıcısı dışında tercih edilen tarayıcının kullanılmasına olanak tanır. SSL kullanılan bir uygulamanın trafiği yakalanmak istenirse sertifika yüklenmesi gerekmektedir.

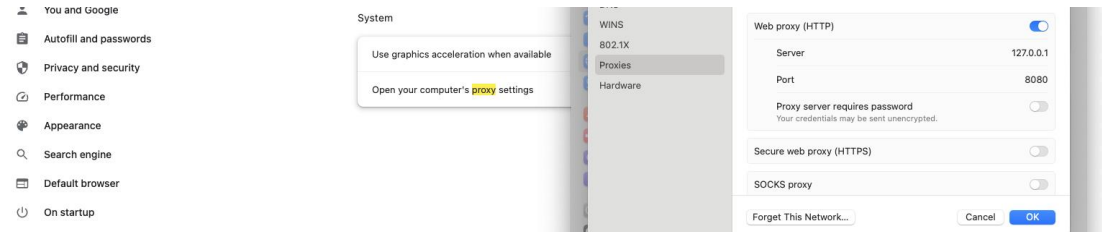
## Burp Suite Proxy Ayarlarının Yapılandırılması

Proxy paneline erişmek için, Burp Suite'te sol üst köşede bulunan "Proxy" (Proxy) sekmesine ve ardından "Options" (Seçenekler) alt sekmesine tıklayın. Proxy dinleme ayarlarınızı yapılandırmak için "Add" (Ekle) butonuna tıklayarak yeni bir dinleme portu ekleyin. Genellikle varsayılan olarak 127.0.0.1 adresinde ve 8080 portu kullanılır. "Running" (Çalışıyor) seçeneğini işaretleyerek proxy sunucunuzu aktifleştirin.



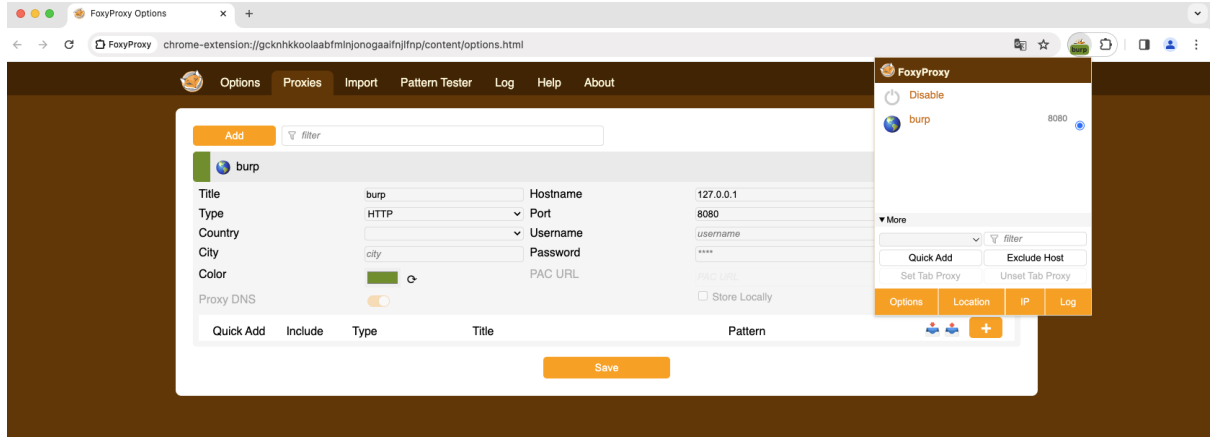
## Tarayıcıya Proxy Ayarlarının Yapılandırılması

Tarayıcınızın ayarlarına giderek ağ veya proxy ayarları bölümünü bulun. Burada, "Manuel proxy yapılandırması" seçeneğini seçin ve HTTP Proxy alanına 127.0.0.1 adresini, Port alanına ise 8080 numarasını girin. Bu işlem tarayıcınızın tüm trafiklerini Burp Suite üzerinden yönlendirecektir.



FoxyProxy, proxy ayarlarınızı kolayca yönetmenizi sağlayan bir tarayıcı eklentisidir. Proxy ayarlarını tarayıcı ayarlarından yapmak istemiyorsanız eklenti kullanabilirsiniz. Tarayıcı eklenti mağazasından eklentiye tarayıcınıza kurduktan sonra, FoxyProxy simgesine tıklayarak "Options" (Seçenekler) menüsüne erişin. Yeni bir proxy profili oluşturun ve Burp Suite'in dinleme ayarlarına uygun şekilde 127.0.0.1 adresini ve 8080 portunu ayarlayın. Bu profil aktifken, tarayıcı trafiğiniz Burp Suite üzerinden yönlendirilecektir.

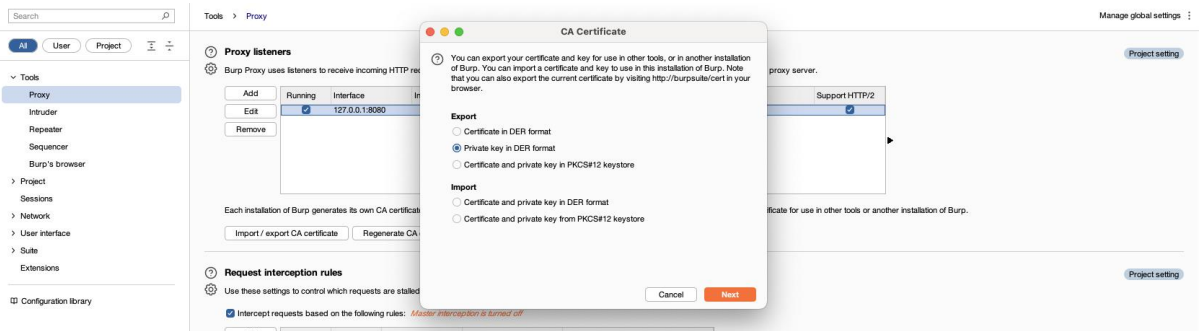




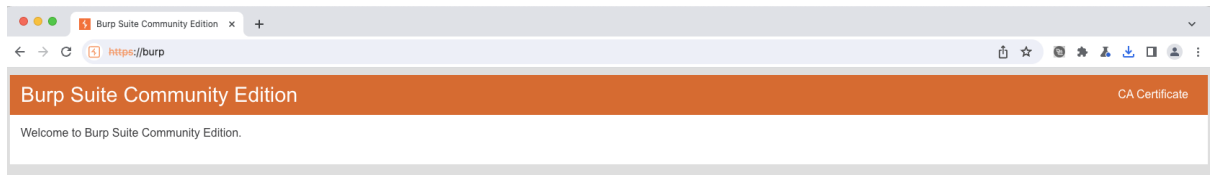
## Burp Suite Sertifikasının Üretilmesi ve İndirilmesi

Tarayıcınızda dinleme yapabilmeniz için Burp Suite sertifikasının tarayıcınıza yüklenmesi gerekmektedir.

"Proxy" (Proxy) > "Options" (Seçenekler) sekmesine gidin ve "Import / export CA certificate" (CA sertifikasını içe/dışa aktar) seçeneğine tıklayın. "Der" formatında sertifikayı kaydetmek için "Export" (Dışa aktar) düğmesine tıklayın ve dosyayı bilgisayarınıza kaydedin



Tarayıcı üzerinden de sertifikayı indirmek mümkündür. <http://burp> adresi ziyaret edilir. Sağ üst kısımda bulunan 'CA Certificate' butonuna tıklandığında "Der" uzantılı bir sertifika indirilmektedir.



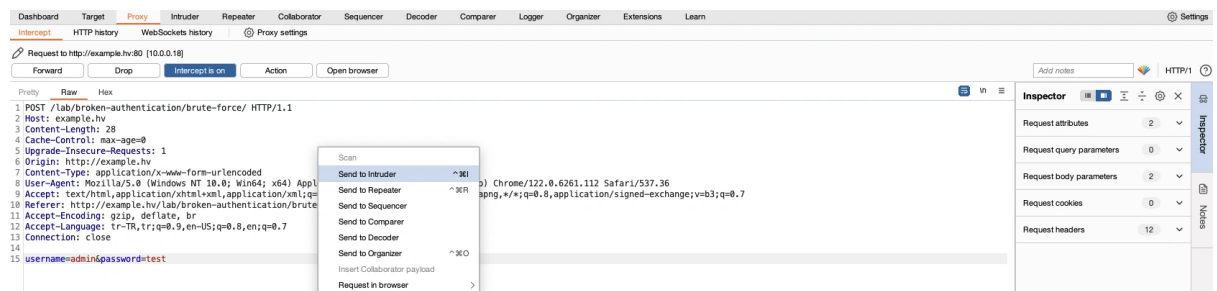
## Tarayıcıya Sertifika Yükleme

Tarayıcıya bağlı olarak, sertifika yükleme adımları değişiklik gösterebilir. Tarayıcı ayarlarına giderek "Gizlilik ve Güvenlik" seçeneğini bulun.

"Sertifikaları Yönet" üzerinden "Güvenilir Kök Sertifika Yetkilileri"ne geçiş yapın ve "İçe Aktar" ile Burp Suite sertifikasını yükleyin.

## Intruder

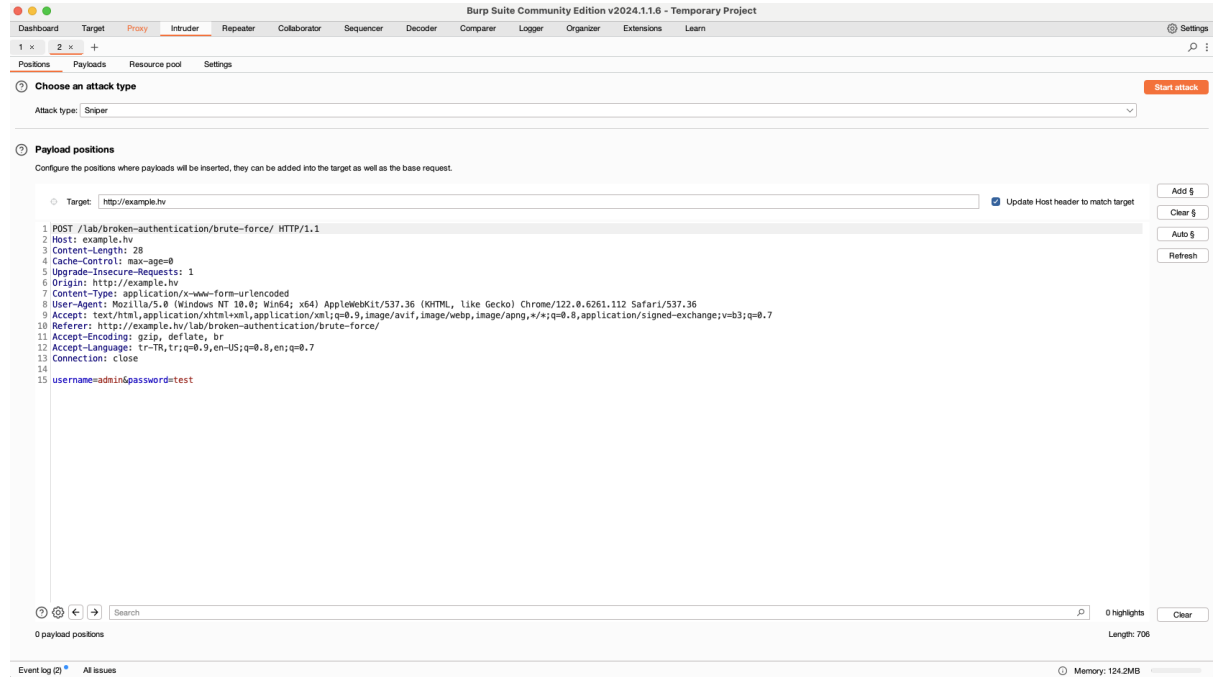
Intruder, Burp Suite içerisinde özelleştirilmiş saldırılar oluşturarak güvenlik zafiyetlerini otomatik olarak test etmek için tasarlanmıştır. Özellikle form veya parametre alanlarında payload denemeleri, fuzzing ve brute-force saldırıları için kullanılmaktadır. Community versiyonunda, yavaş bir tarama hızı sunmasından dolayı performans anlamında başarısı düşüktür. Intruder'ı kullanmak için Site Map, HTTP History gibi isteklerin listelendiği alanda herhangi bir isteğin üzerinde sağ tık yapmak ve "Send to Intruder" seçeneğine tıklamak yeterlidir. Proxy sayfasında yakalanan isteği Intruder aracına göndermek için ise boş bir yerde sağ tık yapmak ve "Send to Intruder" seçeneğine tıklanması gerekmektedir.



## Positions

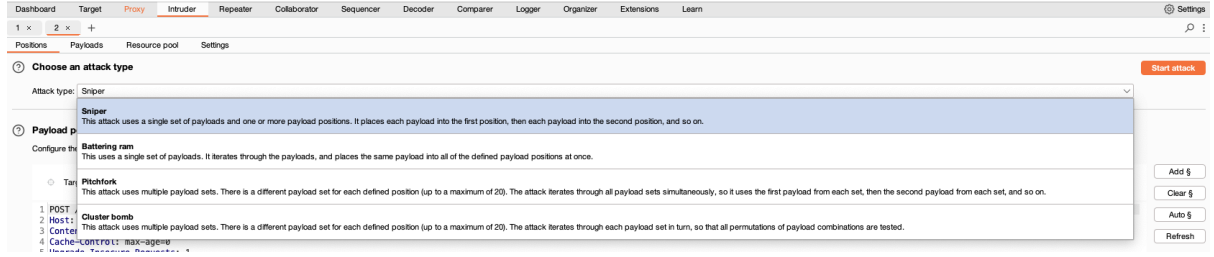
Positions bölümü, saldırının gerçekleştirileceği ve verilerin değiştirileceği alanları belirlenmesini sağlar. Hangi parametrelerin veya veri noktalarının hedef olarak saldırıda kullanılacağı tanımlanır.

Seçilen istek Intruder aracına gönderildiğinde bu bölümde görünmektedir.



Bu bölümde saldırı sırasında payload'ların nasıl dağıtılacağını belirlemesine olanak tanıyan çeşitli "Attack Type" (Saldırı Tipi) seçeneği bulunur. Her bir saldırı tipi, farklı bir amaca yönelik olarak kullanılabilir ve payload'ların hedef üzerinde nasıl kullanılacağını tanımlar.

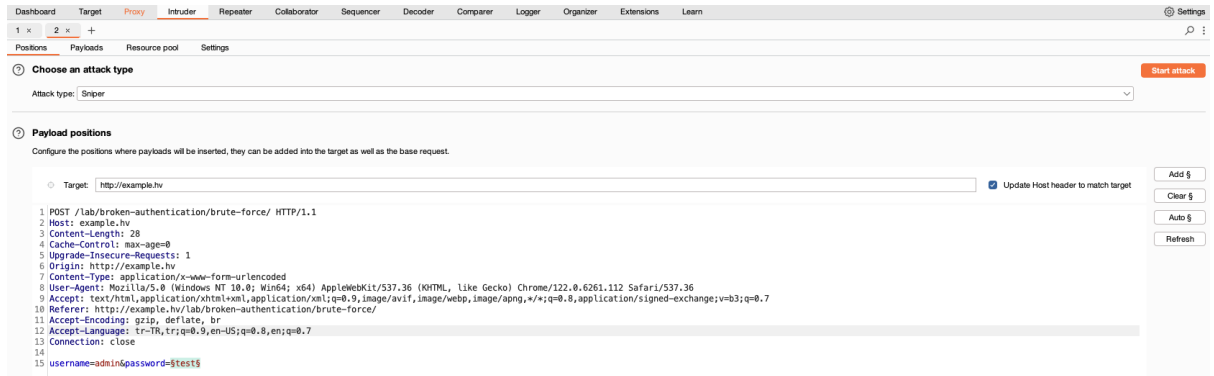
- **Sniper:** Tek bir parametre için birçok farklı payload denenmek istendiğinde kullanılmaktadır. Örneğin bir formdaki kullanıcı adı alanı veya URL parametresi için idealdir.
- **Battering Ram:** Birden fazla parametre için hepsinde aynı payload denenmek istendiğinde kullanılmaktadır. Örneğin XSS gibi güvenlik açıklarını test etmek için ve birçok girdi noktası üzerinde aynı payload'ın etkisini görmek istendiğinde idealdir.
- **Pitchfork:** Tüm parametreler için ayrı payload'lar çapraz olarak denenmek istendiğinde kullanılmaktadır. Birinci parametre için birinci payload listesinden eleman, ikinci parametre için ikinci payload listesinden eleman denir daha sonra çapraz olarak birinci parametre için ikinci payload listesinden eleman, ikinci parametre için birinci payload listesinden eleman denir.
- **Cluster Bomb:** Tüm parametreler için ayrı payload'lar sadece parametreye özel olarak kullanılır. Çaprazlama bir deneme yapılmamaktadır. Birinci parametre için birinci payload listesinden eleman, ikinci parametre için ikinci payload listesinden eleman denir.



## Kullanımı

- Otomatik Pozisyon Belirleme:** Intruder, yüklenecek isteği otomatik olarak analiz eder ve muhtemel değişkenler için pozisyonlar önerir. Otomatik seçilenleri silmek için "Clear" butonu kullanılmalıdır.
- Manuel Pozisyon Ayarlama:** Özel ihtiyaçlara göre pozisyonları manuel olarak seçilebilir. Bu, "§" simgesi ile belirtilen başlangıç ve bitiş işaretleyicileri arasında alınarak yapılır. Fare imleci ile hedef noktalar seçilip "Add" butonuna basılarak bu işlem gerçekleştirilebilmektedir.
- Pozisyon Türleri:** Saldırı türüne bağlı olarak "Sniper", "Battering Ram", "Pitchfork" veya "Cluster Bomb" gibi farklı pozisyon türleri seçilebilir.

Burada bir giriş formunda bulunan username ve password parametresi hedef alınmıştır. password parametresinde bulunan "test" değeri hedef olarak seçilmiş olup bu değere deneme yapılması belirlenmiştir. "admin" kullanıcısının parolasının bulunması hedeflenmiştir. Tek bir parametre için bir payload listesi verileceği için sniper modu seçilmiştir.



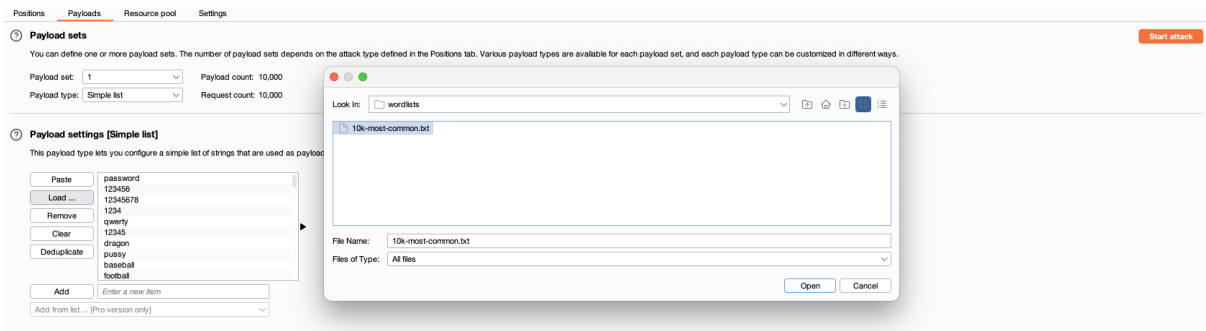
## Payloads

Payloads bölümü, saldırıda kullanılacak olan veri setleridir. XSS, SQL Injection gibi güvenlik açıkları için payload listeleri, izin listeleri, kullanıcı adı

parola listeleri gibi kullanılmak istenen payload listeleri bu bölümden yüklenmektedir.

- **Payload Sets:** Farklı payload listelerini tanımlamanıza ve yönetmenize olanak tanır, her set saldırıda kullanılmak üzere Burp Suite içerisinde hazır ve veri setleri içerir.
- **Payload Settings:** Seçilen payload listesinin yüklenmesi ve yeni payload'ın eklenmesi bu kısımda yapılır.
- **Payload Processing:** Payload'ların gönderilmeden önce uygulanacak özel kuralların tanımlanmasına (örneğin, verilerin şifrelenmesi, kodlanması veya değiştirilmesi) olanak tanır.
- **Payload Encoding:** Gönderilen payload'ların nasıl kodlanacağını (URL kodlama, HTML kodlama vb.) belirlemenize olanak tanır, bu da farklı hedef ortamlarda uygun biçimde işlenmelerini sağlar.

Burada "Load" butonu ile SecLists içerisinde bulunan 10k-most-common.txt isimli sıkça kullanılan parola listelerinden biri yüklenmiştir.



## Sık Tercih Edilen Parola Listeleri ve Diğer Kaynaklar

Saldırılarda başarı oranını artırmak için doğru veri setini kullanmak kritiktir. Sektör standardı haline gelmiş kaynaklar aşağıdadır.

### 1. SecLists

Güvenlik testleri için en kapsamlı arşivdir. Kullanıcı adları, parolalar, URL'ler, hassas veri kalıpları ve fuzzing payload'larını içerir. Burp Suite'te en sık kullanılan listeler bu arşivin

Passwords/Common-Credentials dizininde yer alır.

- **Ana Depo (Repository):** <https://github.com/danielmiessler/SecLists>
- **Sık Kullanılan Parolalar Dizini:** [Common-Credentials Dizini](#)

**Hızlı Erişim İçin Popüler Dosyalar:** Aşağıdaki dosyalar, gerçek veri sızıntılarından derlenmiş en yaygın parolaları içerir ve Intruder saldırılarına başlamak için idealdir:

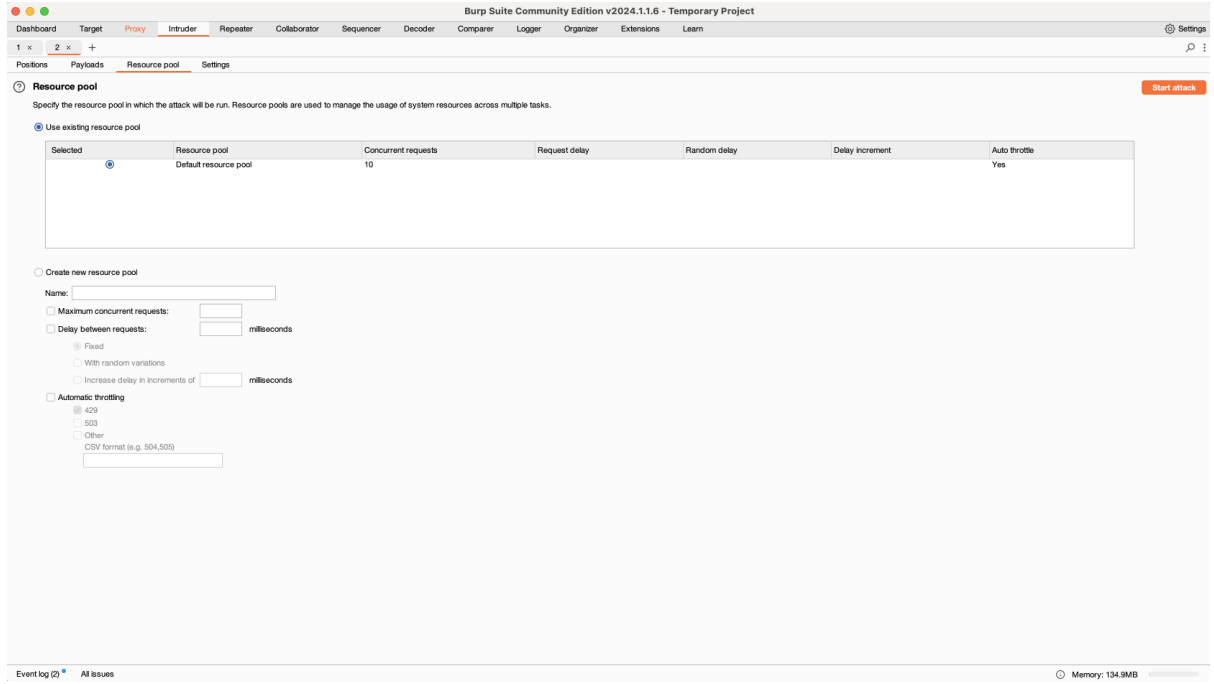
- **10k-most-common.txt:**  
<https://github.com/danielmiessler/SecLists/blob/master/Passwords/Common-Credentials/10k-most-common.txt>
- **darkweb2017\_top-100.txt:**  
[https://github.com/danielmiessler/SecLists/blob/master/Passwords/Common-Credentials/darkweb2017\\_top-100.txt](https://github.com/danielmiessler/SecLists/blob/master/Passwords/Common-Credentials/darkweb2017_top-100.txt)
- **darkweb2017\_top-1000.txt:**  
[https://github.com/danielmiessler/SecLists/blob/master/Passwords/Common-Credentials/darkweb2017\\_top-1000.txt](https://github.com/danielmiessler/SecLists/blob/master/Passwords/Common-Credentials/darkweb2017_top-1000.txt)
- **darkweb2017\_top-10000.txt:**  
[https://github.com/danielmiessler/SecLists/blob/master/Passwords/Common-Credentials/darkweb2017\\_top-10000.txt](https://github.com/danielmiessler/SecLists/blob/master/Passwords/Common-Credentials/darkweb2017_top-10000.txt)

## 2. Diğer Önemli Payload Kaynakları

- **PayloadsAllTheThings:** Web uygulama güvenliği (SQLi, XSS, RCE vb.) için özelleşmiş payload listeleri sunar.  
<https://github.com/swisskyrepo/PayloadsAllTheThings>
- **FuzzDB:** Uygulamalardaki hataları tetiklemek için kullanılan saldırı kalıplarını içerir. <https://github.com/fuzzdb-project/fuzzdb>
- **Assetnote Wordlists:** Otomatik taramalarla oluşturulan ve sürekli güncellenen modern sözlüklerdir. <https://wordlists.assetnote.io/>

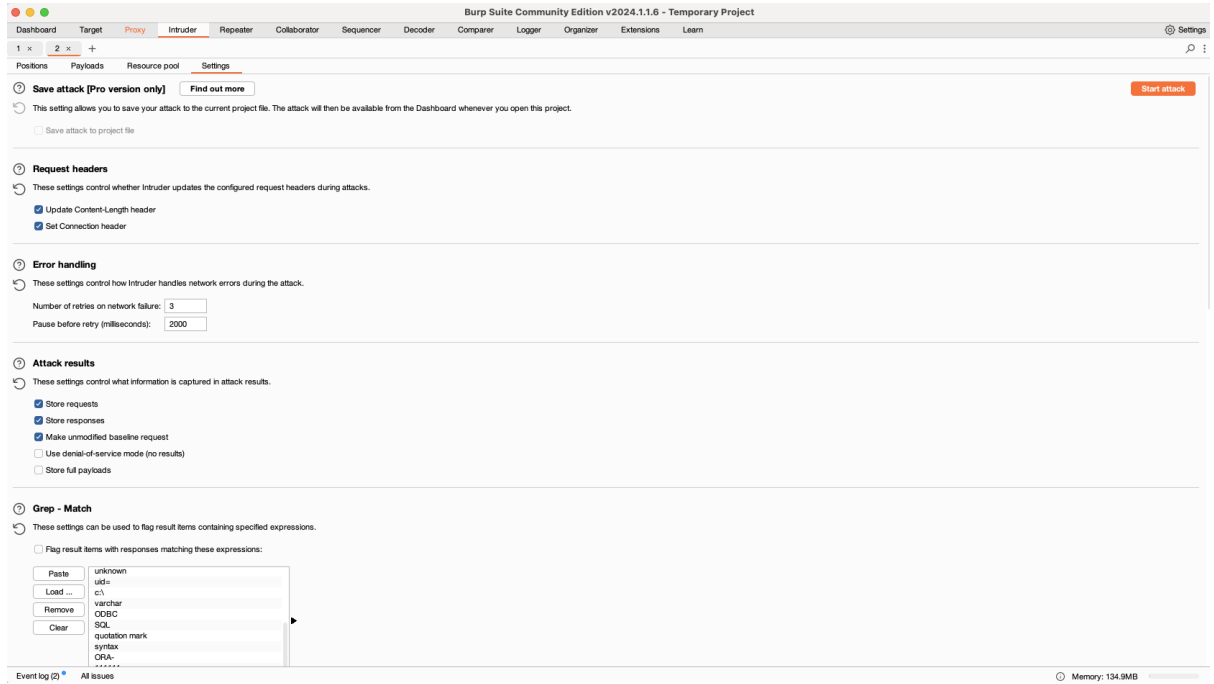
## Resource Pool

Intruder saldırılarının kaynak kullanımını yönetmek için kullanılır. Aynı anda yapılabilecek istek sayısını ve genel kaynak tüketimini kontrol etmek amacıyla tasarlanmıştır.



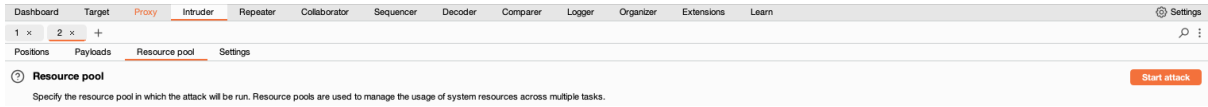
## Settings

Intruder saldırılarının çeşitli yönlerini özelleştirmek için kullanılır. Bu ayarlar, saldırının nasıl gerçekleştirileceği, zaman aşımı süreleri, HTTP başlıkları gibi detayları içerir.

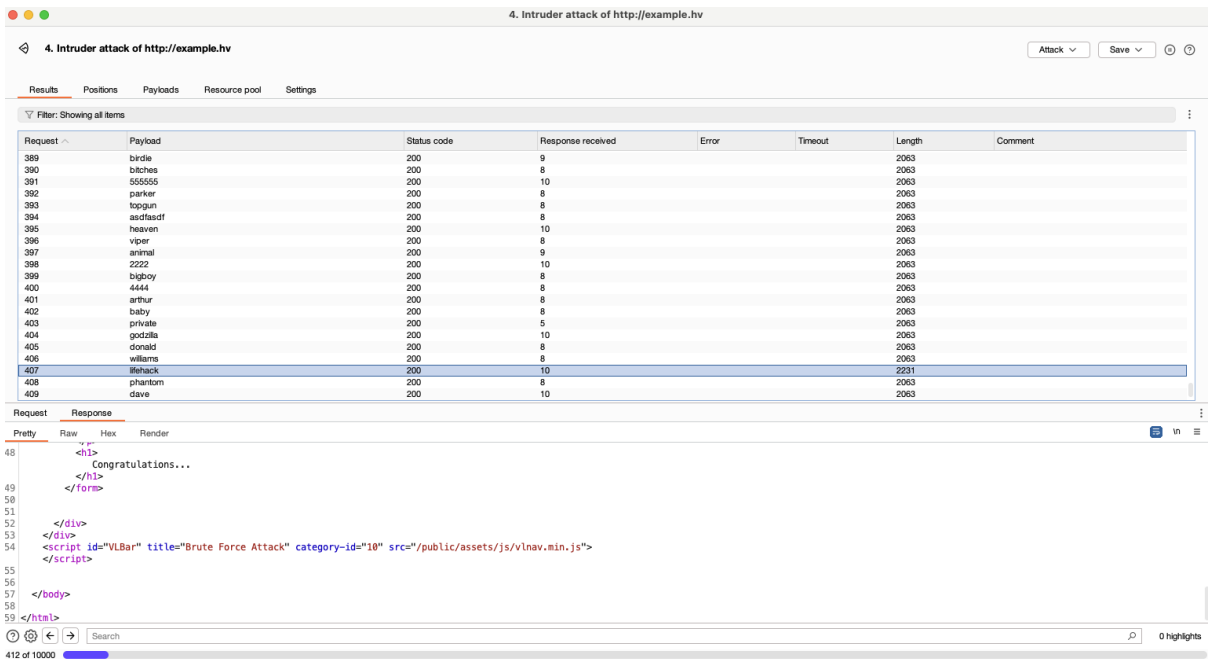


## Saldırının Başlatılması

Positions bölümünde hedef parametreler belirlenir, Payloads bölümünde veri seti yüklenir. Gerekirse diğer bölümlerde bulunan yapılandırmalar tamamlanır. Tüm işlemler tamamlandıktan sonra sağ üst kısımda bulunan "Start Attack" butonuna tıklanarak saldırı başlatılır.



Saldırı penceresinde yapılan denemelerin Request ve Response bilgileri bulunmaktadır. Denenen payload'ların listesinde HTTP durum kodu, yanıt boyutu gibi bilgiler yer almaktadır. Doğru payload'ın tespit edilmesi için Response bilgileri incelenebilir. Bu örnekte tüm HTTP durum kodları aynı 200 olarak döndüğü için durum kodu işe yaramamaktadır. Yanıt boyutu farklı olan dikkat çekmekte olup doğru parola "lifehack" olarak tespit edilmiştir.

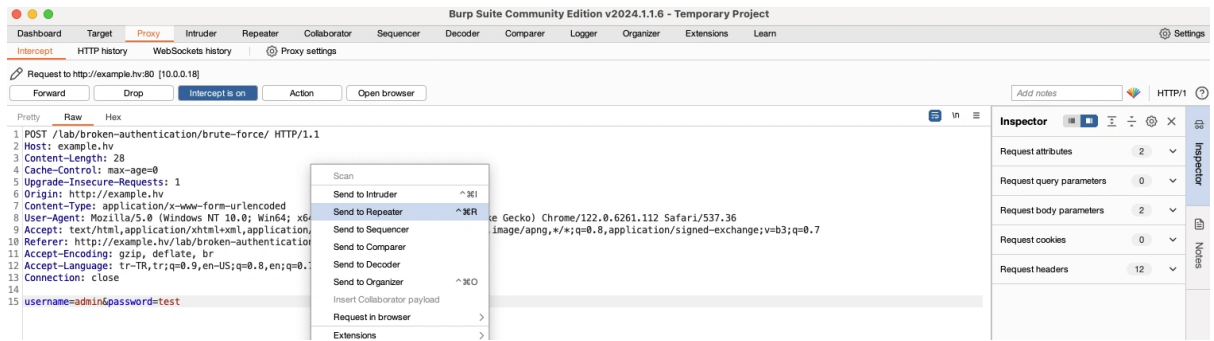




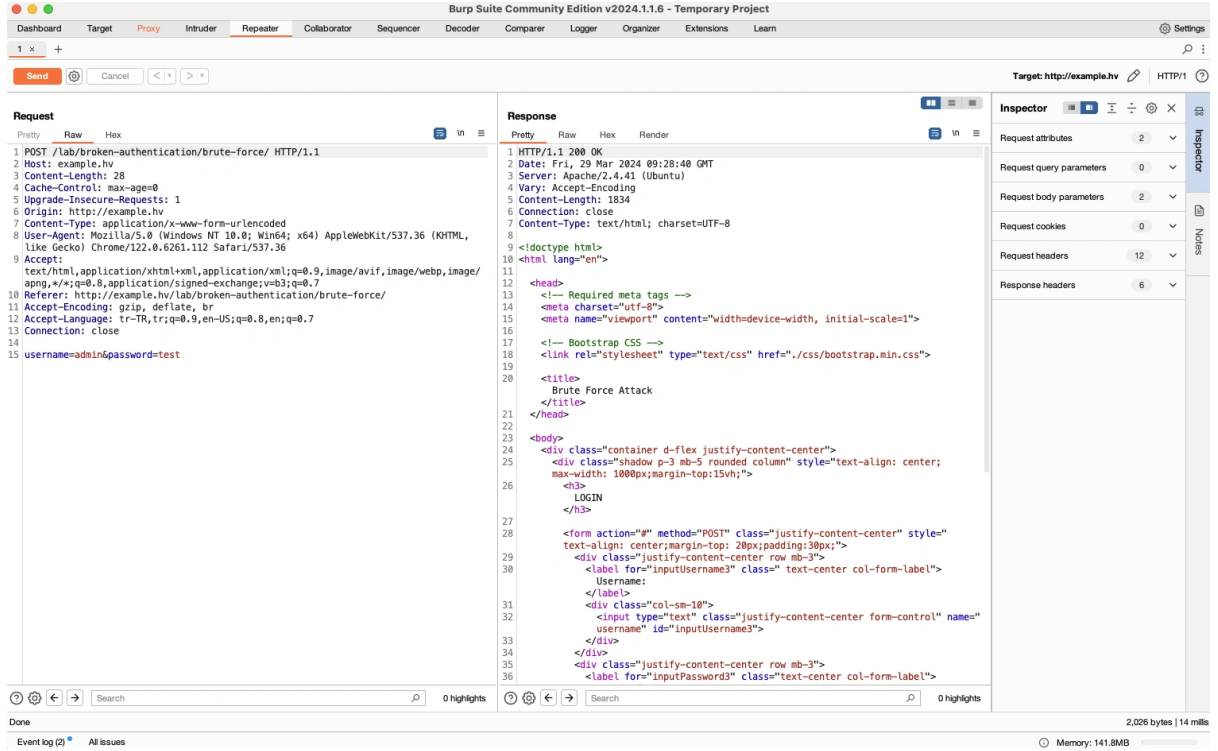
## Repeater

Repeater, isteklerin manuel olarak düzenlenip tekrar gönderilebilmesini sağlayan bir araçtır. Bu özellik, güvenlik testleri sırasında hedef uygulamanın nasıl tepki verdiğini gözlemlemek için öneme sahiptir. İstekler üzerinde yapılan değişikliklerin sonuçlarını hızlı bir şekilde görüntülemek, güvenlik açıklarının belirlenmesine katkı sağlayacaktır.

Repeater'ı kullanmak için, öncelikle bir isteği yakalamak gerekir. Bu istek, Burp Suite'in Proxy modülü aracılığıyla yakalanabilir ya da başka bir Burp Suite aracından Repeater'a gönderilebilir.



1. **İstek Yakalama:** Burp Suite'in Proxy (Proxy) özelliğini kullanarak trafik üzerinden bir istek yakalayın.
2. **Repeater'a Gönderme:** Yakalanan isteği sağ tıklayarak "Send to Repeater" (Repeater'a Gönder) seçeneğini seçin.
3. **Düzenleme ve Gönderme:** Repeater sekmesine geçiş yapın. İstekte değişiklik yapmak istediğiniz alanları bulun ve gerekli düzenlemeleri yapın. Değişiklikler tamamlandığında, "Send" butonuna tıklayarak isteği tekrar gönderin.



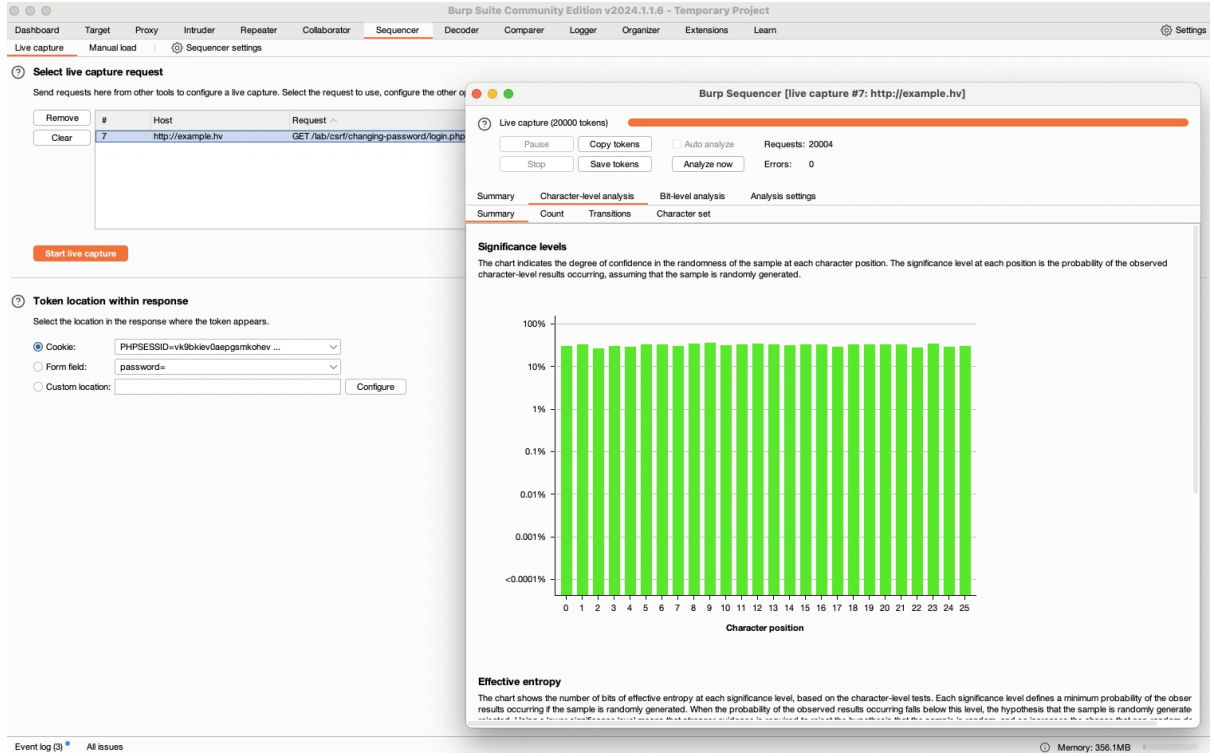
## Response

İstek gönderildikten sonra, yanıt Repeater arayüzünün sağ bölümünde görüntülenir. Buradan HTTP yanıt kodu, yanıt başlıkları ve yanıt içeriği gibi bilgilere erişilebilir. Yanıtları incelemek, hedef uygulamanın farklı isteklere nasıl tepki verdiğinin anlaşılmasına yardımcı olmaktadır.

- **Metod Değiştirme:** GET, POST gibi HTTP metodunu değiştirebilirsiniz.
- **URL Düzenleme:** İstek yapılan URL'i değiştirebilirsiniz.
- **Başlıklar ve Parametreler:** HTTP başlıklarını ve gönderilen verileri (örneğin, form verileri) düzenleyebilirsiniz.

## Sequencer

Sequencer, web uygulamalarında kullanılan oturum anahtarlarını (token) ve diğer verilerin ne kadar güvenli olduğunu test etmek için kullanılan bir araçtır. Sequencer, bu belirteçlerin rastgeleliğini ve tahmin edilemezliğini analiz eder, böylece bir saldırganın session hijacking gibi saldırıları gerçekleştirme olasılığını değerlendirir.



## Sequencer ile Veri Toplama

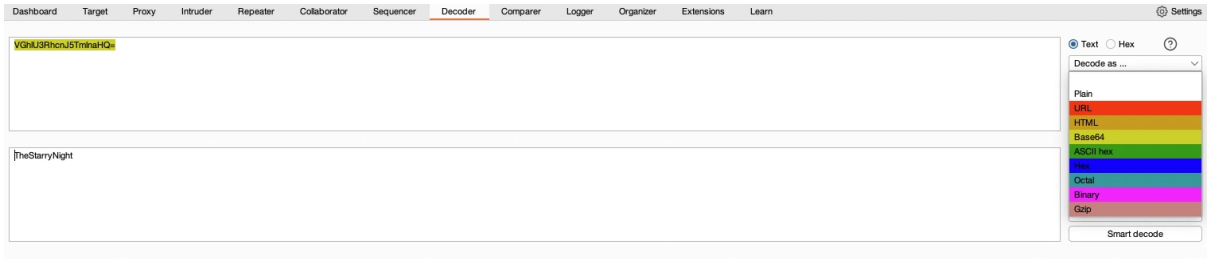
- Proxy Aracılığıyla Trafik Yakalama:** Burp Suite'in Proxy özelliği kullanılarak, web uygulamasının trafik akışı yakalanır. Bu, genellikle oturum açma işlemleri veya diğer hassas işlemler sırasında üretilen token değerlerini içerir.
- Sequencer'e Veri Gönderme:** Yakalanan isteklerden birine sağ tıklayarak "Send to Sequencer" seçeneğini kullanıldığında ilgili veri Sequencer'a gönderilecektir.

## Analiz Süreci

- Token Seçimi:** Sequencer arayüzünde, analiz etmek istenilen veri seçilir. Bu, bir oturum anahtarı, CSRF token'ı veya başka bir veri olabilir.
- Veri Toplama:** Sequencer, token güvenliğini değerlendirebilmek için yeterli sayıda örnek toplamalıdır. "Start live capture" (Canlı yakalamayı başlat) butonuna basarak, Sequencer token örneklerini toplamaya başlar. Genellikle, istatistiksel olarak geçerli sonuçlar alabilmek için binlerce örnek gerekir.
- Analiz:** Toplanan veri üzerinde, rastgelelik ve tahmin edilemezlik gibi çeşitli testler uygulanır. Sequencer, bu testlerin sonuçlarını kullanarak belirteçlerin ne kadar güvenli olduğu hakkında detaylı bir rapor üretir.

## Decoder

Decoder, Burp Suite'in kodlanmış, şifrelenmiş veya karmaşılaştırılmış verileri çözümlmek ve dönüştürmek için kullanılan aracıdır. Bu araç, güvenlik testleri sırasında karşılaşılan verilerin analizini kolaylaştırır. Çözmenin yanında mevcut olan yöntemler ile veriyi kodlama, şifreleme gibi yeteneklere de sahiptir.



## Veri Girme

Decoder aracına veri girişi, iki yöntemle gerçekleştirilebilir:

- **Manuel Giriş:** Decoder sekmesindeki metin kutusuna, çözümlenmek üzere olan veri doğrudan yazılabilir veya yapıştırılabilir.
- **Diğer Araçlardan Gönderme:** Burp Suite içerisindeki Proxy, Repeater gibi diğer araçlardan yakalanan veriler, "Send to Decoder" (Decoder'a Gönder) seçeneği ile doğrudan Decoder'a aktarılabilir.

## Veri Çözümleme

Decoder arayüzünde, çözümlenmek istenilen veri formatı seçilir. Bu işlem için çeşitli birçok dönüştürme seçeneği mevcuttur.

**Smart Decode:** Verinin kodlama türünü otomatik olarak algılayıp çözer.

**Unicode Kodlama/Çözme:** Metni Unicode kodlarına dönüştürür veya bu kodlardan metine çözümleme yapar.

### Desteklenen Kodlama Yöntemlerinden Bazıları

- URL Kodunu Çözme
- HTML Kodunu Çözme
- Base64 Kodunu Çözme

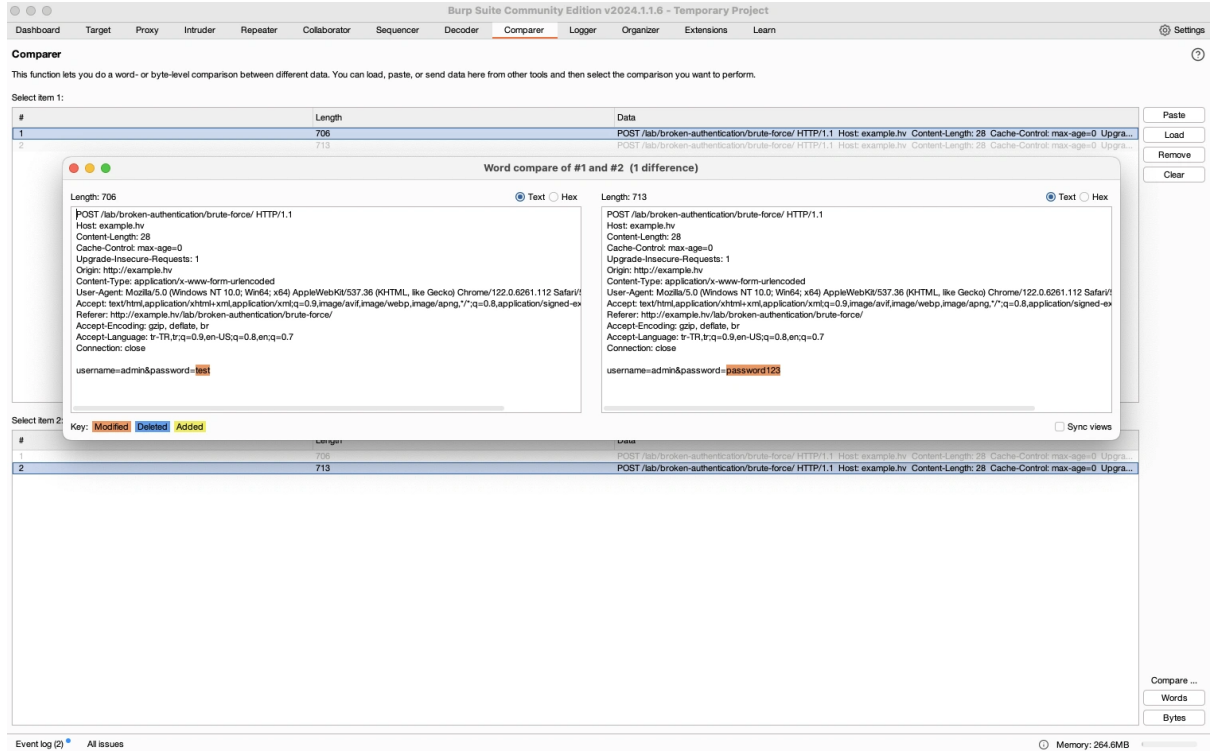
- ASCII Hex Kodunu Çözme
- Hex Kodunu Çözme
- Octal Kodunu Çözme
- Binary Kodunu Çözme
- GZIP Sıkıştırmaı Çözme

### **Desteklenen Hash Yöntemlerinden Bazıları**

- MD2
- MD4
- MD5
- SHA-1
- SHA-256
- SHA-512

### **Comparer**

Comparer, iki veya daha fazla veri parçasının karşılaştırılmasını ve farklarının analiz edilmesini sağlar. Bu araç, özellikle güvenlik testleri sırasında, benzer iki işlem arasındaki ince farkları belirlemek veya iki farklı oturum belirtecinin yapısal farklarını anlamak gibi durumlarda kullanışlıdır. Comparer ile yapılan analizler, güvenlik açıklarının belirlenmesine yardımcı olabilir ve uygulamanın nasıl davrandığını daha iyi anlamayı sağlar.



## Comparer Kullanımı

### Veri Karşılaştırma Türleri

Comparer, iki ana karşılaştırma modu sunar: **Bytes** ve **Words**.

- **Bytes Mod:** Verilerin byte düzeyinde karşılaştırılması için tasarlanmıştır. Binary dosyalar, resimler veya şifreli veriler bu modda karşılaştırılabilir.
- **Words Mod:** Metin tabanlı verilerin karşılaştırılması için kullanılır. HTML kodları, JSON yanıtları veya düz metin gibi içerikler bu modda incelenebilir.

### Veri Girişi

Comparer'a veri girişi yapmanın birkaç yolu vardır:

- **Manuel Giriş:** Karşılaştırılmak istenilen veriler doğrudan Comparer'ın arayüzüne yazılabilir veya yapılandırılabilir.
- **Diğer Araçlardan Gönderme:** Burp Suite içerisindeki Proxy, Repeater gibi diğer araçlardan yakalanan veriler, "Send to Comparer" (Comparer'a Gönder) seçeneği ile doğrudan Comparer'a aktarılabilir.

### Karşılaştırma ve Analiz

Karşılaştırma işlemi başlatıldığında, Comparer iki veri seti arasındaki farkları görsel olarak vurgular. Text modunda, farklı metin satırları veya karakterler renk kodları ile işaretlenir. Bytes modda ise, byte düzeyindeki farklılıklar gösterilir.

Karşılaştırma sonuçları, güvenlik açıklarının belirlenmesinde, uygulama mantığının anlaşılmasında veya belirli işlemlerin sonuçlarının neden farklı olduğunun detaylı bir şekilde incelenmesinde kullanılabilir.

## Logger

Logger, Burp Suite kullanılırken gerçekleştirilen tüm istek ve yanıtların kaydını tutar. Bu, güvenlik testleri sırasında yapılan işlemlerin incelenmesi, hata ayıklanması ve potansiyel güvenlik açıklarının tespit edilmesi için öneme sahiptir.

**Logger ve HTTP History arasındaki fark**, Logger'ın Burp Suite üzerinden geçen her türlü trafik bilgisini kaydetmesi ve daha geniş bir izleme sağlaması, HTTP History'nin ise daha çok manuel test sırasında yapılan ve kullanıcı etkileşimleri ile oluşan trafiklere odaklanmasıdır. Her iki araç da güvenlik testleri ve uygulama analizi için değerli bilgiler sunar, ancak kullanım amacına göre tercih edilmeleri gerekir.

The screenshot displays the Burp Suite Community Edition v2024.1.16 - Temporary Project interface. The top menu bar includes Dashboard, Target, Proxy, Intruder, Repeater, Collaborator, Sequencer, Decoder, Comparer, Logger, Organizer, Extensions, and Learn. The Logger tab is active, showing a table of captured requests. The table has columns for #, Time, Tool, Method, Host, Path, Query, Param count, Status code, Length, Start response timer, and Comment. The first request is a GET request to example.hv with a status code of 200 and a length of 17942. The second request is a GET request to example.hv with a status code of 304 and a length of 144. The third request is a GET request to example.hv with a status code of 304 and a length of 144. The fourth request is a GET request to example.hv with a status code of 200 and a length of 14150. The fifth request is a GET request to example.hv with a status code of 304 and a length of 144. The sixth request is a GET request to example.hv with a status code of 304 and a length of 144. The seventh request is a GET request to example.hv with a status code of 200 and a length of 371226. The eighth request is a GET request to example.hv with a status code of 200 and a length of 13473. The ninth request is a GET request to example.hv with a status code of 200 and a length of 18886. The tenth request is a GET request to example.hv with a status code of 200 and a length of 62060. The eleventh request is a GET request to example.hv with a status code of 200 and a length of 16678. The twelfth request is a GET request to example.hv with a status code of 304 and a length of 144. The thirteenth request is a GET request to example.hv with a status code of 200 and a length of 142128. The fourteenth request is a GET request to example.hv with a status code of 304 and a length of 144. The fifteenth request is a GET request to example.hv with a status code of 304 and a length of 144. The sixteenth request is a GET request to example.hv with a status code of 304 and a length of 144. The seventeenth request is a GET request to example.hv with a status code of 304 and a length of 144. The eighteenth request is a GET request to example.hv with a status code of 304 and a length of 144. The nineteenth request is a GET request to example.hv with a status code of 304 and a length of 144. The twentieth request is a GET request to example.hv with a status code of 304 and a length of 144.

The Request details pane shows the following information:

- Request: GET / HTTP/1.1
- Host: example.hv
- Upgrade-Insecure-Requests: 1
- User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/122.0.6261.112 Safari/537.36
- Sec-Purpose: prefetch;render
- Purpose: prefetch
- Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,\*/\*;q=0.8,application/signed-exchange;v=b3;q=0.7
- Accept-Encoding: gzip, deflate, br
- Accept-Language: tr-TR,tr;q=0.9,en-US;q=0.8,en;q=0.7
- Connection: close

The Response details pane shows the following information:

- Response: 200 OK
- Date: Fri, 29 Mar 2024 07:10:16 GMT
- Server: Apache/2.4.41 (Ubuntu)
- Vary: Accept-Encoding
- Content-Length: 17749
- Connection: close
- Content-Type: text/html; charset=UTF-8

The Inspector pane shows the following information:

- Request attributes: 2
- Request headers: 9
- Response headers: 6

The bottom status bar shows the event log (2) and memory usage (264.6MB).

## Organizer

Organizer, test sürecinde elde edilen bulguları, notları ve gözlemleri düzenli bir şekilde saklamaya yardımcı olan bir araçtır. Bu özellik, test edilen uygulama veya sistemler hakkında toplanan bilgilerin yönetilmesi ve raporlanması sürecini kolaylaştırır.

The screenshot shows the Burp Suite interface with the 'Organizer' tab selected. The top bar includes tabs for Dashboard, Target, Proxy, Intruder, Repeater, Collaborator, Sequencer, Decoder, Comparer, Logger, Organizer, Extensions, and Learn. Below the tabs is a filter bar showing 'Showing all items'. The main area displays a table of HTTP requests:

| # | Time                 | Status      | Tool     | Method | Host       | Path                         | Query | Param count | Status code | Length | Notes                        |
|---|----------------------|-------------|----------|--------|------------|------------------------------|-------|-------------|-------------|--------|------------------------------|
| 1 | 14:13:33 29 Mar 2024 | Done        | Repeater | GET    | example.hv | /lab/csrf/changing-password/ |       | 0           |             |        | GET request has been made to |
| 2 | 14:13:33 29 Mar 2024 | In progress | Proxy    | GET    | example.hv | /lab/csrf/changing-password/ |       | 1           | 200         | 4440   |                              |
| 3 | 14:13:18 29 Mar 2024 | New         | Proxy    | GET    | example.hv | /vuln/3                      |       | 1           | 200         | 11823  |                              |

Below the table, the 'Request' tab is selected, showing the raw HTTP request details for the first item. The request is a GET request to /lab/csrf/changing-password/login.php. The response tab is also visible, showing the raw response details. The 'Notes' tab is selected, showing a note for the first request: 'GET request has been made to http://example.hv/lab/csrf/changing-password/login.php. This is a login page.'

## Organizer Kullanımı

### Yeni Not Ekleme

- Not Ekleme:** "Add note" (Not ekle) butonuna tıklayarak yeni bir not eklenebilir. Bu notlar, belirli bir bulgu hakkında detaylar, test edilen uygulamanın belirli bir özelliği veya potansiyel bir güvenlik açığı hakkında önemli bilgiler içerebilir.
- Detaylar:** Açılan pencerede, not için bir başlık ve detaylar eklenebilir. İstenirse, not belirli bir kategoriye atanabilir. Bu, sonradan notları filtrelemeyi ve yönetmeyi kolaylaştırır.

### Sınıflandırma

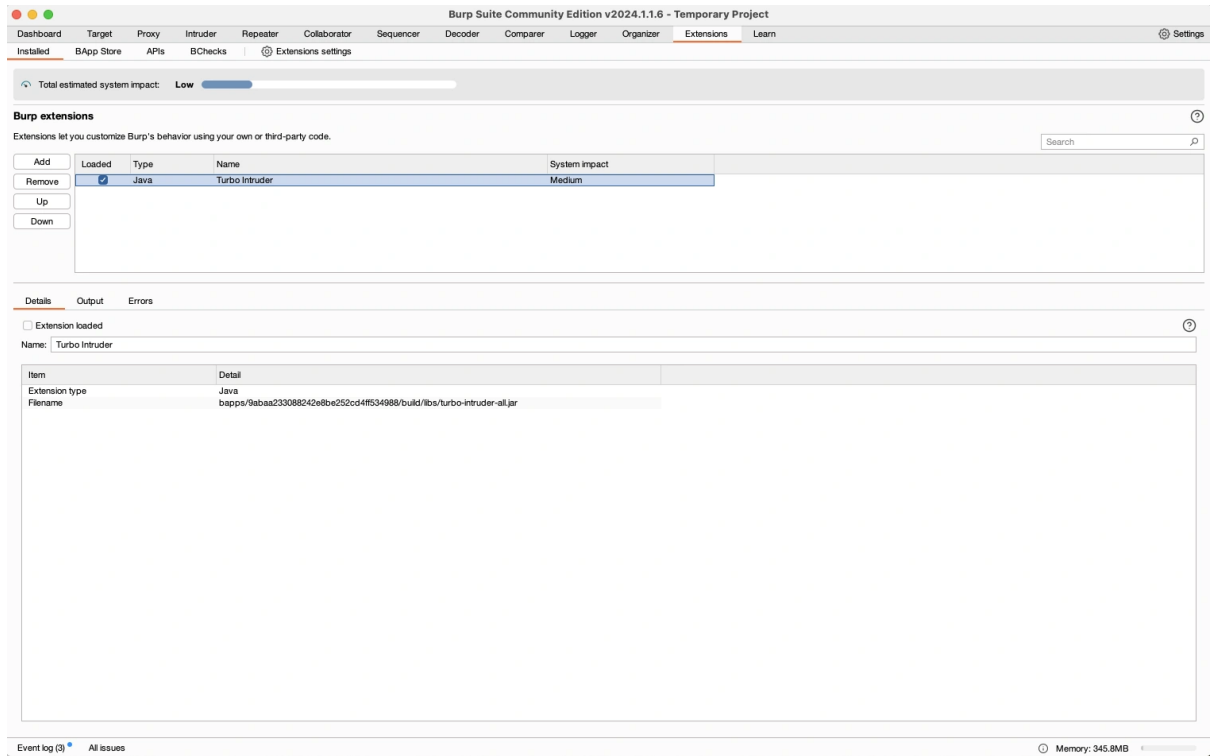
Listede bir trafiğin üstüne gelinip sağ tıklandığında çeşitli işlemler gerçekleştirilebilmektedir. Örneğin, Highlight özelliği ile satırlar



renklendirilebilmektedir. Status özelliği ile New (Yeni), In Progress (İşlemde), Done (Tamamlandı) gibi durumlar atanabilmektedir.

## Extensions

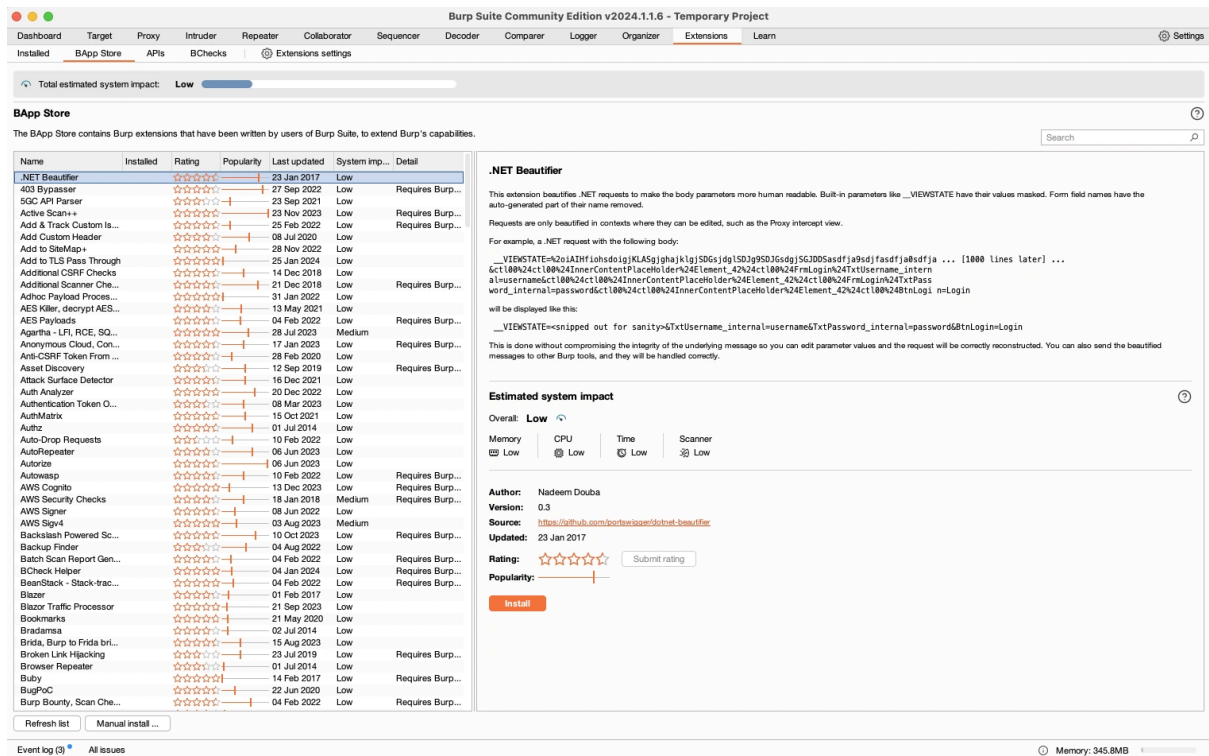
Extensions, Burp Suite'in işlevselliğini artıran eklentilerdir. Bu eklentiler, güvenlik test süreçlerinin özelleştirilmesine, yeni özellikler eklenmesine ve çeşitli görevlerin otomatikleştirilmesine imkan tanımaktadır.



## Eklenti Yükleme

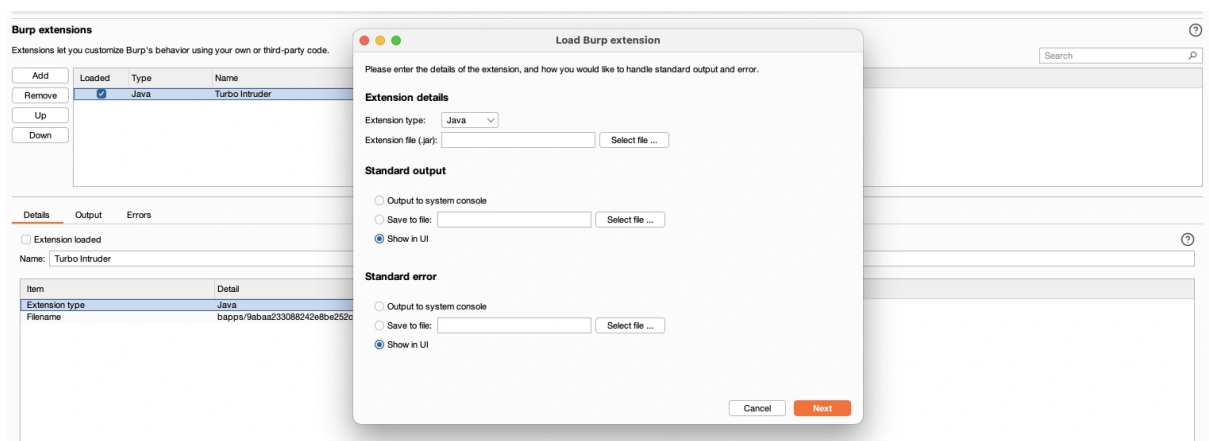
### BApp Store'dan Yükleme

1. **Extensions Sekmesine Erişim:** Burp Suite'te "Extensions" sekmesine gidin.
2. **BApp Store Sekmesini Seçin:** Mevcut eklentiler listesini görüntülemek için "BApp Store" sekmesini seçin.
3. **Eklenti Yükleme:** İlgilendiğiniz eklenti bulun ve "Install" butonuna tıklayarak yükleyin.



## Manuel Yükleme

1. **Eklenti Dosyasını İndirin:** İndirilecek eklenti dosyasını (.jar veya .py) hazırlayın.
2. **Extensions Sekmesine Gitme:** "Extensions" sekmesini açın.
3. **"Add" Butonu:** "Add" butonuna tıklayın.
4. **Eklenti Bilgilerini Girme:** Eklentinin tipini seçin (Java veya Python) ve "Select file" ile dosyayı bulun.
5. **Yükleme:** "Next" veya "OK" ile eklentiği yükleyin.



## Sık Kullanılan Burp Suite Eklentileri

1. **Turbo Intruder:** Güçlü bir HTTP saldırı aracıdır ve gelişmiş saldırılar için hızlı bir şekilde HTTP istekleri göndermeyi sağlar.

2. **SQLMap for Burp Suite:** Popüler SQLMap aracının özelliklerini Burp Suite içerisinde kullanmanıza olanak tanıyan bir eklentidir, SQL enjeksiyon zafiyetlerini otomatik olarak tespit etmek ve sömürmek için kullanılır.
3. **Authorize:** Otomatik olarak yetkilendirme kontrolleri yaparak, uygulamaların güvenlik zafiyetlerini tespit etmeye yardımcı olur; erişim kontrolü zafiyetlerini keşfetmek için kullanılır.
4. **Active Scan++:** Burp Suite'in yerleşik pasif ve aktif tarama yeteneklerini geliştirir, daha geniş kapsamlı güvenlik zafiyetlerini tespit etmek için kullanılır.
5. **403 Bypass:** Web uygulamalarındaki erişim kısıtlamalarını (HTTP 403 Forbidden) aşma yöntemlerini otomatik test etmek için kullanılır.

## Extensions Kullanımı

Yüklenen eklentiler, Burp Suite kullanıcı arayüzünde genellikle yeni bir sekme, menü öğesi veya araç çubuğu düğmesi olarak görünür. Eklenti kullanmak için bu yeni arayüz elemanlarından birine tıklayıp ve eklentinin yönergeleri takip edilmelidir.

### Extensions Güncelleme ve Kaldırma

#### Güncelleme

Eklentiler, genellikle otomatik olarak ya da manuel olarak güncellenir. BApp Store'dan yüklenen eklentiler için, "Extensions" sekmesinden güncellemeleri kontrol edilerek ve talimatları takip edilmelidir.

#### Kaldırma

Kaldırılmak istenen eklenti "Extensions" listesinden seçilip "Remove" butonuna tıklayarak kaldırılabilir.

#### API'ler

Burp Suite geliştiricilere Burp Suite'in çeşitli işlevlerini genişletme ve özelleştirme imkanı sunar. API'ler aracılığıyla, geliştiriciler kendi eklentilerini oluşturabilir, mevcut iş akışlarını otomatikleştirebilir ve Burp Suite'in güvenlik testi süreçlerine entegre yeni özellikler geliştirebilirler.

Burp Suite Community Edition v2024.1.1.6 - Temporary Project

DashboardTargetProxyIntruderRepeaterCollaboratorSequencerDecoderComparerLoggerOrganizerExtensionsLearn

InstalledBApp StoreAPIsBChecksExtensions settings

Settings

Burp Extender APIs

You can use the Burp Extender APIs to create your own extensions to customize Burp's behavior.

BurpExtension

MontoyaApi

> burpsuite

> collaborator

> comparer

> core

> decoder

> extension

> http

> internal

> intruder

> logger

> logging

> organizer

> persistence

> proxy

> repeater

> scanner

> scope

> sitemap

> ui

> utilities

> websocket

```
1 /*
2  * Copyright (c) 2022-2023. PortSwigger Ltd. All rights reserved.
3  *
4  * This code may be used to extend the functionality of Burp Suite Community Edition
5  * and Burp Suite Professional, provided that this usage does not violate the
6  * license terms for those products.
7  */
8
9 package burp.api.montoya;
10
11 /**
12  * All extensions must implement this interface.
13  * <p>
14  * Implementations must be declared public, and must provide a default (public, no-argument) constructor.
15  */
16 public interface BurpExtension
17 {
18     /**
19      * Invoked when the extension is loaded. Any registered handlers will only be enabled once this method has completed.
20      *
21      * @param api The API implementation to access the functionality of Burp Suite.
22      */
23     void initialize(MontoyaApi api);
24 }
```

Save interface files

Save Javadoc files

Event log (3) All issues

Memory: 345.8MB

